

DETECTION ENGINEERING 2026

**100 PRIORITY USE CASES, ALERT
DETECTIONS & CORRELATION RULES**

By Izzmier Izzuddin

Contents - 20 Detection Domains

- 01. Identity & Authentication - 5 priority rules
- 02. Active Directory & Kerberos - 5 priority rules
- 03. Endpoint Execution & LOLBins - 5 priority rules
- 04. Persistence & Privilege Escalation - 5 priority rules
- 05. Credential Access - 5 priority rules
- 06. Discovery & Lateral Movement - 5 priority rules
- 07. Defense Impairment & Stealth - 5 priority rules
- 08. Email & Collaboration - 5 priority rules
- 09. Network, DNS, Proxy & C2 - 5 priority rules
- 10. Web, WAF & Application - 5 priority rules
- 11. Cloud IaaS - 5 priority rules
- 12. SaaS, M365 & OAuth - 5 priority rules
- 13. Containers & Kubernetes - 5 priority rules
- 14. DevOps, CI/CD & Source Control - 5 priority rules
- 15. Collection & Exfiltration - 5 priority rules
- 16. Ransomware & Impact - 5 priority rules
- 17. Threat Intelligence & IOC - 5 priority rules
- 18. Vulnerability & Exposure - 5 priority rules
- 19. Detection Health & Telemetry - 5 priority rules
- 20. Cross-Source Correlation & Attack Chains - 5 priority rules

01. Identity & Authentication

Detect abuse of passwords, sessions, MFA, service accounts, and identity lifecycle events before an attacker converts a valid identity into persistent access.

ID	Rule	Severity
DE-001	Password Spray Across Many Accounts	High
DE-002	Failed Logons Followed by Successful Logon	High
DE-003	Impossible or Highly Atypical Travel	High
DE-004	MFA Method Added After Risky Sign-in	Critical
DE-005	Service Account Interactive Logon	High

DE-001 - Password Spray Across Many Accounts

Domain	Identity & Authentication
ATT&CK	T1110.003 Password Spraying
Severity	High
Window	10m
Telemetry	Identity provider, VPN, Windows authentication
Fields	timestamp, user, source_ip, device_id, result, auth_method, risk_level, app, location, session_id
Source Library ID	DE-001
ATT&CK v19.2 Artifact	Direct: DET0487 - Distributed Password Spraying via Authentication Failures Across Multiple Accounts
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - alert when one source or device generates failed logons against many distinct user accounts with low attempts per account; raise confidence if followed by any success - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Alert when one source or device generates failed logons against many distinct user accounts with low attempts per account; raise confidence if followed by any success GROUP/RELATE BY user account and source/device WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved vulnerability scanners and identity health checks; baseline NAT egress sources
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Alert when one source or device generates failed logons against many distinct user accounts with low attempts per account; raise confidence if followed by any success
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic failed-authentication records for at least 15 users from one test source, then confirm the correlation fires

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Password Spray Across Many Accounts' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-002 - Failed Logons Followed by Successful Logon

Domain	Identity & Authentication
ATT&CK	T1110 Brute Force; T1078 Valid Accounts
Severity	High
Window	10m
Telemetry	Windows Security, IdP, VPN
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-004
ATT&CK v19.2 Artifact	Composite: DET0463 - Brute Force Authentication Failures with Multi-Platform Log Correlation; DET0560 - Detection of Valid Account Abuse Across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate a burst of failures with a subsequent successful authentication for the same account and compatible source within the same window - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate a burst of failures with a subsequent successful authentication for the same account and compatible source within the same window GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Suppress known user password-reset testing and approved access gateways that retry automatically
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate a burst of failures with a subsequent successful authentication for the same account and compatible source within the same window
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic failure events followed by a success and confirm one correlated case is created

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Failed Logons Followed by Successful Logon' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-003 - Impossible or Highly Atypical Travel

Domain	Identity & Authentication
ATT&CK	T1078 Valid Accounts
Severity	High
Window	2h
Telemetry	Cloud IdP, VPN, authentication risk data
Fields	timestamp, principal, source_ip, session_id, action, resource, region, result, user_agent, device_id
Source Library ID	DE-005
ATT&CK v19.2 Artifact	Direct/Contextual: DET0560 - Detection of Valid Account Abuse Across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect successive successful sign-ins from locations that cannot reasonably be traversed in the observed interval; add risk for new device or new ASN - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect successive successful sign-ins from locations that cannot reasonably be traversed in the observed interval; add risk for new device or new ASN GROUP/RELATE BY user/host/source entity WITHIN 2h THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude trusted corporate VPN egress, satellite links, and known travel proxies; prefer device and session continuity over geo alone
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect successive successful sign-ins from locations that cannot reasonably be traversed in the observed interval; add risk for new device or new ASN
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.

- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Create two synthetic successful sign-ins for one test user from widely separated test geolocations and confirm alerting

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Impossible or Highly Atypical Travel' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-004 - MFA Method Added After Risky Sign-in

Domain	Identity & Authentication
ATT&CK	T1098 Account Manipulation
Severity	Critical
Window	30m
Telemetry	IdP audit, MFA registration, sign-in risk
Fields	timestamp, user, source_ip, device_id, result, auth_method, risk_level, app, location, session_id
Source Library ID	DE-008
ATT&CK v19.2 Artifact	Composite: DET0190 - Detect MFA Modification or Disabling Across Platforms; DET0096 - Account Manipulation Behavior Chain Detection
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate a risky or first-seen sign-in with registration of a new MFA device, phone, authenticator, or passwordless method - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate a risky or first-seen sign-in with registration of a new MFA device, phone, authenticator, or passwordless method
GROUP/RELATE BY user account and source/device WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved onboarding and device-replacement workflows with ticket/change references
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.

- Confirm the exact condition that matched: Correlate a risky or first-seen sign-in with registration of a new MFA device, phone, authenticator, or passwordless method
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic risky sign-in followed by MFA-method registration for a test user

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'MFA Method Added After Risky Sign-in' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-005 - Service Account Interactive Logon

Domain	Identity & Authentication
ATT&CK	T1078.002 Domain Accounts
Severity	High
Window	15m
Telemetry	Windows Security, Linux auth, PAM, service account inventory
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-010
ATT&CK v19.2 Artifact	Direct/Contextual: DET0210 - Abuse of Domain Accounts
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - alert when a non-human service identity performs interactive, remote interactive, console, or browser-based authentication inconsistent with its purpose - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Alert when a non-human service identity performs interactive, remote interactive, console, or browser-based authentication inconsistent with its purpose GROUP/RELATE BY user account and source/device WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Maintain authoritative service-account inventory and expected hosts; exclude approved break-glass procedures
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Alert when a non-human service identity performs interactive, remote interactive, console, or browser-based authentication inconsistent with its purpose
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Generate a synthetic interactive logon for a designated lab service account and confirm the rule fires

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Service Account Interactive Logon' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

02. Active Directory & Kerberos

Protect the enterprise identity control plane by monitoring account creation, privilege changes, Kerberos abuse, replication access, and directory enumeration.

ID	Rule	Severity
DE-006	New Domain Account Created	Medium
DE-007	Account Added to Privileged Group	Critical
DE-008	Directory Replication Abuse / DCSync-Like Request	Critical
DE-009	Kerberoasting - Excessive TGS Requests	High
DE-010	Golden Ticket Suspicion	Critical

DE-006 - New Domain Account Created

Domain	Active Directory & Kerberos
ATT&CK	T1136.002 Create Account: Domain Account
Severity	Medium
Window	10m
Telemetry	Windows Security, AD audit
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-011
ATT&CK v19.2 Artifact	Direct: DET0003 - T1136.002 Detection Strategy - Domain Account Creation Across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - alert on domain account creation; raise severity when creator is unusual, outside JML workflow, or account is immediately used - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Alert on domain account creation; raise severity when creator is unusual, outside JML workflow, or account is immediately used GROUP/RELATE BY source host and queried domain WITHIN 10m THEN create or raise a MEDIUM detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Suppress approved IAM/JML provisioning connectors and expected service principals
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Alert on domain account creation; raise severity when creator is unusual, outside JML workflow, or account is immediately used
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.

- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay Windows 4720-style synthetic account-creation data for a lab identity

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'New Domain Account Created' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-007 - Account Added to Privileged Group

Domain	Active Directory & Kerberos
ATT&CK	T1098 Account Manipulation
Severity	Critical
Window	5m
Telemetry	Windows Security, AD audit
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-012
ATT&CK v19.2 Artifact	Direct: DET0310 - Suspicious Addition to Local or Domain Groups
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect additions to Domain Admins, Enterprise Admins, Administrators, Backup Operators, or other designated tier-0 groups - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect additions to Domain Admins, Enterprise Admins, Administrators, Backup Operators, or other designated tier-0 groups GROUP/RELATE BY user account and source/device WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Use an authoritative privileged-group list; exclude approved PAM elevation with ticket reference
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect additions to Domain Admins, Enterprise Admins, Administrators, Backup Operators, or other designated tier-0 groups
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Generate a synthetic privileged-group membership addition and verify a critical case

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Account Added to Privileged Group' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-008 - Directory Replication Abuse / DCSync-Like Request

Domain	Active Directory & Kerberos
ATT&CK	T1003.006 OS Credential Dumping: DCSync
Severity	Critical
Window	5m
Telemetry	AD object access, domain controller telemetry
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-014
ATT&CK v19.2 Artifact	Direct: DET0594 - Detection of Unauthorized DCSync Operations via Replication API Abuse
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect directory replication rights or replication API activity initiated by non-domain-controller identities or unexpected hosts - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect directory replication rights or replication API activity initiated by non-domain-controller identities or unexpected hosts GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow only known domain controllers and approved identity sync infrastructure; investigate any new replication principal
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect directory replication rights or replication API activity initiated by non-domain-controller identities or unexpected hosts
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Generate representative AD 4662-style replication access events from a lab non-DC principal

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Directory Replication Abuse / DCSync-Like Request' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-009 - Kerberoasting - Excessive TGS Requests

Domain	Active Directory & Kerberos
ATT&CK	T1558.003 Steal or Forge Kerberos Tickets: Kerberoasting
Severity	High
Window	15m
Telemetry	Windows Security Kerberos events
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-015
ATT&CK v19.2 Artifact	Direct: DET0157 - Detect Kerberoasting Attempts (T1558.003)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect one user requesting many service tickets for distinct SPNs in a short period, especially with encryption types associated with offline cracking risk - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect one user requesting many service tickets for distinct SPNs in a short period, especially with encryption types associated with offline cracking risk GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline legitimate service discovery and monitoring accounts; exclude approved assessment tooling
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.

- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect one user requesting many service tickets for distinct SPNs in a short period, especially with encryption types associated with offline cracking risk
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic 4769-like TGS requests for many SPNs from one lab user

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Kerberoasting - Excessive TGS Requests' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-010 - Golden Ticket Suspicion

Domain	Active Directory & Kerberos
ATT&CK	T1558.001 Steal or Forge Kerberos Tickets: Golden Ticket
Severity	Critical
Window	30m
Telemetry	Kerberos, DC authentication, identity analytics
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-017
ATT&CK v19.2 Artifact	Direct: DET0144 - Detect Forged Kerberos Golden Tickets (T1558.001)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect anomalous TGT usage such as impossible lifetime, unusual encryption or domain fields, privileged access without preceding normal authentication, or ticket reuse from unexpected hosts - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect anomalous TGT usage such as impossible lifetime, unusual encryption or domain fields, privileged access without preceding normal authentication, or ticket reuse from unexpected hosts GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Correlate several anomalies rather than relying on one field; account for trusted forests and PAM systems
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.

- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect anomalous TGT usage such as impossible lifetime, unusual encryption or domain fields, privileged access without preceding normal authentication, or ticket reuse from unexpected hosts
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic anomalous TGT metadata in a lab stream and verify correlation

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Golden Ticket Suspicion' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

03. Endpoint Execution & LOLBins

Identify suspicious execution and abuse of trusted operating-system utilities by using process lineage, command line, signer, path, and network context.

ID	Rule	Severity
DE-011	Office Application Spawns PowerShell	High
DE-012	MSHTA Suspicious Execution	High
DE-013	Certutil Download or Decode Abuse	High
DE-014	WMI Remote Process Creation	High
DE-015	New Executable in Temp Followed by External Connection	High

DE-011 - Office Application Spawns PowerShell

Domain	Endpoint Execution & LOLBins
ATT&CK	T1059.001 Command and Scripting Interpreter: PowerShell
Severity	High
Window	5m
Telemetry	EDR/Sysmon process creation

Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-021
ATT&CK v19.2 Artifact	Direct: DET0455 - Abuse of PowerShell for Arbitrary Execution
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect WINWORD, EXCEL, POWERPNT, OUTLOOK, or similar productivity process launching PowerShell or pwsh - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect WINWORD, EXCEL, POWERPNT, OUTLOOK, or similar productivity process launching PowerShell or pwsh GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude known add-ins or approved automation only with exact parent path, signer, and command pattern
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect WINWORD, EXCEL, POWERPNT, OUTLOOK, or similar productivity process launching PowerShell or pwsh
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Launch a harmless PowerShell Write-Output command from a controlled test harness that simulates an Office parent event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Office Application Spawns PowerShell' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-012 - MSHTA Suspicious Execution

Domain	Endpoint Execution & LOLBins
ATT&CK	T1218.005 System Binary Proxy Execution: Mshta

Severity	High
Window	10m
Telemetry	EDR process and network telemetry
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-023
ATT&CK v19.2 Artifact	Direct: DET0506 - Detecting Mshta-based Proxy Execution via Suspicious HTA or Script Invocation Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.
Artifact Trace	

THREAT HYPOTHESIS

If the organization observes the described pattern - detect mshta.exe executing remote content, unusual script arguments, user-writable paths, or spawning script/shell children - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect mshta.exe executing remote content, unusual script arguments, user-writable paths, or spawning script/shell children
GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude signed enterprise applications that legitimately invoke mshta with stable paths and no external URLs
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect mshta.exe executing remote content, unusual script arguments, user-writable paths, or spawning script/shell children
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Use a benign local HTML test file and synthetic remote-URL metadata in the lab

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'MSHTA Suspicious Execution' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-013 - Certutil Download or Decode Abuse

Domain	Endpoint Execution & LOLBins
ATT&CK	T1105 Ingress Tool Transfer; T1140 Deobfuscate/Decode Files or Information
Severity	High
Window	15m
Telemetry	EDR process, command line, proxy/network
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-026
ATT&CK v19.2 Artifact	Composite: DET0060 - Detect Ingress Tool Transfers via Behavioral Chain; DET0275 - Detect Adversary Deobfuscation or Decoding of Files and Payloads
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect certutil used with URL cache, download, decode, or unusual file-output arguments from interactive users - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect certutil used with URL cache, download, decode, or unusual file-output arguments from interactive users GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude certificate-administration servers and approved PKI workflows by host and command pattern
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect certutil used with URL cache, download, decode, or unusual file-output arguments from interactive users
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic certutil -urlcache or -decode command telemetry without contacting a live malicious site

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Certutil Download or Decode Abuse' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.

- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-014 - WMI Remote Process Creation

Domain	Endpoint Execution & LOLBins
ATT&CK	T1047 Windows Management Instrumentation
Severity	High
Window	10m
Telemetry	WMI logs, EDR, Windows authentication
Fields	timestamp, user, source_ip, device_id, result, auth_method, risk_level, app, location, session_id
Source Library ID	DE-028
ATT&CK v19.2 Artifact	Direct: DET0364 - Behavioral Detection Strategy for WMI Execution Abuse on Windows
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect process creation through WMI from a remote source, especially from non-management hosts or after credential-access activity - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect process creation through WMI from a remote source, especially from non-management hosts or after credential-access activity GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow SCCM, monitoring, and approved administration subnets; correlate with account role
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect process creation through WMI from a remote source, especially from non-management hosts or after credential-access activity
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic WMI process-creation and remote-authentication records between lab hosts

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'WMI Remote Process Creation' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-015 - New Executable in Temp Followed by External Connection

Domain	Endpoint Execution & LOLBins
ATT&CK	T1105 Ingress Tool Transfer; T1204.002 User Execution: Malicious File
Severity	High
Window	15m
Telemetry	EDR file/process/network
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-030
ATT&CK v19.2 Artifact	Composite: DET0060 - Detect Ingress Tool Transfers via Behavioral Chain; correlate with process/file/network analytics
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate creation of an executable or script in Temp/Downloads with execution and a new external connection from the same process tree - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate creation of an executable or script in Temp/Downloads with execution and a new external connection from the same process tree GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude software updaters using signed packages and stable vendor domains
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate creation of an executable or script in Temp/Downloads with execution and a new external connection from the same process tree
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Create a harmless test executable marker in a lab temp path and replay external-connection telemetry

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'New Executable in Temp Followed by External Connection' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

04. Persistence & Privilege Escalation

Detect mechanisms that survive reboot/logon or obtain elevated execution, with emphasis on new services, scheduled tasks, autoruns, WMI, and privileged accounts.

ID	Rule	Severity
DE-016	Suspicious Scheduled Task Creation	High
DE-017	New Windows Service Installation	High
DE-018	Registry Run Key or Startup Persistence	High
DE-019	WMI Event Subscription Persistence	High
DE-020	Suspicious UAC Bypass Indicators	High

DE-016 - Suspicious Scheduled Task Creation

Domain	Persistence & Privilege Escalation
ATT&CK	T1053.005 Scheduled Task/Job: Scheduled Task
Severity	High
Window	15m
Telemetry	Windows Task Scheduler, Security, EDR
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-031
ATT&CK v19.2 Artifact	Direct: DET0441 - Detection of Suspicious Scheduled Task Creation and Execution on Windows
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect newly created scheduled tasks that execute from user-writable paths, script interpreters, hidden arguments, or unexpected accounts - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect newly created scheduled tasks that execute from user-writable paths, script interpreters, hidden arguments, or unexpected accounts GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline enterprise software deployment and monitoring tasks by exact task path and creator
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect newly created scheduled tasks that execute from user-writable paths, script interpreters, hidden arguments, or unexpected accounts
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.

- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Create a harmless scheduled task in a lab that runs a benign echo command

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Suspicious Scheduled Task Creation' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-017 - New Windows Service Installation

Domain	Persistence & Privilege Escalation
ATT&CK	T1543.003 Create or Modify System Process: Windows Service
Severity	High
Window	10m
Telemetry	Windows System/Security, EDR
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-032
ATT&CK v19.2 Artifact	Direct: DET0552 - Detection of Windows Service Creation or Modification
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect service creation with binary paths in Temp/AppData, script interpreters, remote shares, or unsigned binaries - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect service creation with binary paths in Temp/AppData, script interpreters, remote shares, or unsigned binaries GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved software deployment systems and signed vendor installers
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect service creation with binary paths in Temp/AppData, script interpreters, remote shares, or unsigned binaries
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Install a benign test service or replay Event 7045/4697-style data in the lab

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'New Windows Service Installation' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-018 - Registry Run Key or Startup Persistence

Domain	Persistence & Privilege Escalation
ATT&CK	T1547.001 Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder
Severity	High
Window	15m
Telemetry	Registry audit, Sysmon, EDR
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-033
ATT&CK v19.2 Artifact	Direct: DET0365 - Detect Registry and Startup Folder Persistence (Windows)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect new or modified Run/RunOnce values pointing to user-writable, script, or unusual executable locations - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect new or modified Run/RunOnce values pointing to user-writable, script, or unusual executable locations GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline legitimate endpoint management and user productivity software with stable signer/path
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect new or modified Run/RunOnce values pointing to user-writable, script, or unusual executable locations
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Create a harmless lab Run key that launches a test marker and remove it after validation

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Registry Run Key or Startup Persistence' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-019 - WMI Event Subscription Persistence

Domain	Persistence & Privilege Escalation
ATT&CK	T1546.003 Event Triggered Execution: Windows Management Instrumentation Event Subscription
Severity	High
Window	30m
Telemetry	WMI logs, Sysmon, EDR
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-034
ATT&CK v19.2 Artifact	Direct: DET0086 - Detect WMI Event Subscription for Persistence via WmiPrvSE Process and MOF Compilation
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect creation of permanent WMI event filters, consumers, or bindings by unusual users or processes - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect creation of permanent WMI event filters, consumers, or bindings by unusual users or processes GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved management tooling with documented WMI subscriptions
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.

- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect creation of permanent WMI event filters, consumers, or bindings by unusual users or processes
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Create or replay benign WMI subscription events in an isolated lab and confirm detection

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'WMI Event Subscription Persistence' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-020 - Suspicious UAC Bypass Indicators

Domain	Persistence & Privilege Escalation
ATT&CK	T1548.002 Abuse Elevation Control Mechanism: Bypass User Account Control
Severity	High
Window	10m
Telemetry	EDR process, registry, integrity level
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-036
ATT&CK v19.2 Artifact	Direct: DET0388 - Detection Strategy for T1548.002 - Bypass User Account Control (UAC)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect known auto-elevated process relationships, suspicious registry hijacks, or medium-integrity process leading to unexpected high-integrity child - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect known auto-elevated process relationships, suspicious registry hijacks, or medium-integrity process leading to unexpected high-integrity child GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Tune against legitimate installers and accessibility/admin utilities; require multiple signals when possible
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.

- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect known auto-elevated process relationships, suspicious registry hijacks, or medium-integrity process leading to unexpected high-integrity child
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic process-integrity and registry events representing a known benign test pattern

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Suspicious UAC Bypass Indicators' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

05. Credential Access

Detect attempts to obtain passwords, hashes, tokens, browser secrets, cloud credentials, or other authentication material.

ID	Rule	Severity
DE-021	Unusual Process Access to LSASS	Critical
DE-022	SAM/SECURITY/SYSTEM Hive Export	Critical
DE-023	Browser Credential Store Access by Unusual Process	High
DE-024	Search for Passwords or Secrets in Files	Medium
DE-025	Known Credential Dumping Tool or Artifact Pattern	Critical

DE-021 - Unusual Process Access to LSASS

Domain	Credential Access
ATT&CK	T1003.001 OS Credential Dumping: LSASS Memory
Severity	Critical
Window	5m
Telemetry	EDR/Sysmon process access
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256,

	signer, destination
Source Library ID	DE-041
ATT&CK v19.2 Artifact	Direct: DET0363 - Detection of Credential Dumping from LSASS Memory via Access and Dump Sequence
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect non-standard processes requesting high-risk access rights to lsass.exe, especially unsigned tools or processes from user-writable paths - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect non-standard processes requesting high-risk access rights to lsass.exe, especially unsigned tools or processes from user-writable paths GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow EDR/AV, crash dump, and approved diagnostics by signer/hash; keep allowlist narrow
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect non-standard processes requesting high-risk access rights to lsass.exe, especially unsigned tools or processes from user-writable paths
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic process-access telemetry to lsass.exe from a benign lab executable identity

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Unusual Process Access to LSASS' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-022 - SAM/SECURITY/SYSTEM Hive Export

Domain	Credential Access
ATT&CK	T1003.002 OS Credential Dumping: Security Account Manager
Severity	Critical

Window	10m
Telemetry	Windows Security, registry, EDR process
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-042
ATT&CK v19.2 Artifact	Direct: DET0085 - Credential Dumping from SAM via Registry Dump and Local File Access
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect reg.exe, reg save, volume-shadow copy, or direct file access used to obtain SAM, SECURITY, or SYSTEM hives - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect reg.exe, reg save, volume-shadow copy, or direct file access used to obtain SAM, SECURITY, or SYSTEM hives GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved forensic collection and bare-metal backup tooling by host/process
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect reg.exe, reg save, volume-shadow copy, or direct file access used to obtain SAM, SECURITY, or SYSTEM hives
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic reg save commands for lab hive paths without distributing extracted credentials

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'SAM/SECURITY/SYSTEM Hive Export' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-023 - Browser Credential Store Access by Unusual Process

Domain	Credential Access
ATT&CK	T1555.003 Credentials from Password Stores: Credentials from Web Browsers
Severity	High
Window	15m
Telemetry	EDR file/process telemetry
Fields	timestamp, user, host, process_name, file_path, classification, bytes, destination, action, count
Source Library ID	DE-044
ATT&CK v19.2 Artifact	Direct: DET0037 - Detect Suspicious Access to Browser Credential Stores
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect uncommon processes accessing browser Login Data, Cookies, Local State, keychain, or equivalent credential stores - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect uncommon processes accessing browser Login Data, Cookies, Local State, keychain, or equivalent credential stores
GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow browser processes and approved endpoint migration tools; raise severity for unsigned readers
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect uncommon processes accessing browser Login Data, Cookies, Local State, keychain, or equivalent credential stores
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Create synthetic file-access events to lab copies of browser database filenames

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Browser Credential Store Access by Unusual Process' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.

- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-024 - Search for Passwords or Secrets in Files

Domain	Credential Access
ATT&CK	T1552.001 Unsecured Credentials: Credentials In Files
Severity	Medium
Window	30m
Telemetry	EDR process command line, file search, DLP
Fields	timestamp, user, host, process_name, file_path, classification, bytes, destination, action, count
Source Library ID	DE-047
ATT&CK v19.2 Artifact	Direct: DET0412 - Detect Access or Search for Unsecured Credentials Across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect commands or tools searching recursively for password, secret, token, api_key, connection string, private key, or credential-file patterns - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect commands or tools searching recursively for password, secret, token, api_key, connection string, private key, or credential-file patterns GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a MEDIUM detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline developer and security assessment tools; raise severity on servers or after initial compromise signals
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect commands or tools searching recursively for password, secret, token, api_key, connection string, private key, or credential-file patterns
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Run a benign lab search against dummy files containing fake secret markers

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Search for Passwords or Secrets in Files' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.

- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-025 - Known Credential Dumping Tool or Artifact Pattern

Domain	Credential Access
ATT&CK	T1003 OS Credential Dumping
Severity	Critical
Window	10m
Telemetry	EDR process/file/memory telemetry, threat intel
Fields	timestamp, user, host, process_name, file_path, classification, bytes, destination, action, count
Source Library ID	DE-050
ATT&CK v19.2 Artifact	Direct/General: DET0234 - Credential Dumping via Sensitive Memory and Registry Access Correlation
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect known credential-dumping filenames, hashes, module patterns, process behavior, or memory-access signatures; elevate when combined with privileged logon - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect known credential-dumping filenames, hashes, module patterns, process behavior, or memory-access signatures; elevate when combined with privileged logon GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Do not rely on names/hashes alone; prefer behavior and signer/reputation context
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect known credential-dumping filenames, hashes, module patterns, process behavior, or memory-access signatures; elevate when combined with privileged logon
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Use an EICAR-like harmless detection marker or synthetic telemetry representing the tool signature

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Known Credential Dumping Tool or Artifact Pattern' is satisfied.

- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

06. Discovery & Lateral Movement

Recognize internal reconnaissance and movement between systems before the attacker reaches critical assets.

ID	Rule	Severity
DE-026	Domain User and Group Enumeration	Medium
DE-027	Network Service Scanning From User Endpoint	High
DE-028	First-Time RDP to Sensitive Server	High
DE-029	SMB Admin Share Lateral Movement	High
DE-030	WinRM / PowerShell Remoting From Unusual Source	High

DE-026 - Domain User and Group Enumeration

Domain	Discovery & Lateral Movement
ATT&CK	T1087.002 Account Discovery: Domain Account; T1069.002 Permission Groups Discovery: Domain Groups
Severity	Medium
Window	15m
Telemetry	EDR process, AD/LDAP
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-052
ATT&CK v19.2 Artifact	Composite: DET0129 - Domain Account Enumeration Across Platforms; DET0360 - Behavioral Detection of Domain Group Discovery
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect net user /domain, net group, Get-ADUser, LDAP enumeration, or equivalent activity from non-admin endpoints - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect net user /domain, net group, Get-ADUser, LDAP enumeration, or equivalent activity from non-admin endpoints GROUP/RELATE BY source host and queried domain WITHIN 15m THEN create or raise a MEDIUM detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow helpdesk, IAM, inventory, and approved admin workstations; correlate with user role
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect net user /domain, net group, Get-ADUser, LDAP enumeration, or equivalent activity from non-admin endpoints
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.

- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Generate safe read-only directory enumeration in a test OU or replay representative events

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Domain User and Group Enumeration' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-027 - Network Service Scanning From User Endpoint

Domain	Discovery & Lateral Movement
ATT&CK	T1046 Network Service Discovery
Severity	High
Window	5m
Telemetry	Firewall, NDR, endpoint network
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-055
ATT&CK v19.2 Artifact	Direct: DET0376 - Behavioral Detection Strategy for Network Service Discovery Across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect one workstation initiating connection attempts to many hosts/ports in a short period, especially management ports - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect one workstation initiating connection attempts to many hosts/ports in a short period, especially management ports
GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude vulnerability scanners and approved IT discovery subnets; use endpoint role context
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect one workstation initiating connection attempts to many hosts/ports in a short period, especially management ports
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Generate a benign limited scan against dedicated lab targets or replay synthetic flow records

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Network Service Scanning From User Endpoint' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-028 - First-Time RDP to Sensitive Server

Domain	Discovery & Lateral Movement
ATT&CK	T1021.001 Remote Services: Remote Desktop Protocol
Severity	High
Window	30m
Telemetry	Windows Security, RDP logs, asset inventory
Fields	timestamp, host, user, event_id, process_name, parent_process, command_line, source_ip, target, result
Source Library ID	DE-056
ATT&CK v19.2 Artifact	Direct: DET0327 - Multi-event Detection Strategy for RDP-Based Remote Logins and Post-Access Activity
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect RDP authentication from a user/host pair never or rarely observed, especially to domain controllers or critical servers - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect RDP authentication from a user/host pair never or rarely observed, especially to domain controllers or critical servers GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline jump servers, PAM gateways, and operations teams; use first-seen per 30-90 days
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect RDP authentication from a user/host pair never or rarely observed, especially to domain controllers or critical servers
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Perform an approved RDP logon between two lab hosts not present in the test baseline

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'First-Time RDP to Sensitive Server' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-029 - SMB Admin Share Lateral Movement

Domain	Discovery & Lateral Movement
ATT&CK	T1021.002 Remote Services: SMB/Windows Admin Shares
Severity	High
Window	15m
Telemetry	Windows share access, authentication, EDR
Fields	timestamp, user, source_ip, device_id, result, auth_method, risk_level, app, location, session_id
Source Library ID	DE-057
ATT&CK v19.2 Artifact	Direct: DET0530 - Multi-Event Detection for SMB Admin Share Lateral Movement
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect access to ADMIN\$, C\$, IPC\$ followed by file copy or remote execution from unusual workstations/users - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect access to ADMIN\$, C\$, IPC\$ followed by file copy or remote execution from unusual workstations/users GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow software deployment, backup, EDR, and admin jump hosts; correlate with source role
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.

- Confirm the exact condition that matched: Detect access to ADMIN\$, C\$, IPC\$ followed by file copy or remote execution from unusual workstations/users
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Replay synthetic 5140/5145-style share access plus file copy in a lab timeline

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'SMB Admin Share Lateral Movement' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-030 - WinRM / PowerShell Remoting From Unusual Source

Domain	Discovery & Lateral Movement
ATT&CK	T1021.006 Remote Services: Windows Remote Management
Severity	High
Window	15m
Telemetry	WinRM logs, PowerShell, authentication, EDR
Fields	timestamp, user, source_ip, device_id, result, auth_method, risk_level, app, location, session_id
Source Library ID	DE-059
ATT&CK v19.2 Artifact	Direct: DET0477 - Behavioral Detection of WinRM-Based Remote Access
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect remote PowerShell/WinRM sessions initiated from non-management endpoints or by users without admin role - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect remote PowerShell/WinRM sessions initiated from non-management endpoints or by users without admin role GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline automation servers, configuration-management systems, and approved admin workstations
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect remote PowerShell/WinRM sessions initiated from non-management endpoints or by users without admin role
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Open a harmless WinRM session between lab hosts or replay representative telemetry

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'WinRM / PowerShell Remoting From Unusual Source' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

07. Defense Impairment & Stealth

Detect attempts to hide activity, clear evidence, weaken logging, or disable security controls and telemetry.

ID	Rule	Severity
DE-031	EDR or Security Agent Service Stopped	Critical
DE-032	Antivirus Exclusion Added	Critical
DE-033	Windows Security Log Cleared	Critical
DE-034	Critical Telemetry Disappears After Suspicious Activity	Critical
DE-035	Process Masquerading - Name/Path/Signer Mismatch	High

DE-031 - EDR or Security Agent Service Stopped

Domain	Defense Impairment & Stealth
ATT&CK	T1562.001 Impair Defenses: Disable or Modify Tools
Severity	Critical
Window	5m
Telemetry	EDR health, Windows/Systemd service logs
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-061
ATT&CK v19.2 Artifact	Direct: DET0497 - Detection of Defense Impairment through Disabled or Modified Tools across OS

Artifact Trace

Platforms

Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect stop, disable, kill, uninstall, or unexpected termination of EDR/AV/security-agent services - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect stop, disable, kill, uninstall, or unexpected termination of EDR/AV/security-agent services GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Integrate approved maintenance windows and agent-upgrade workflows; alert if heartbeat also disappears
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect stop, disable, kill, uninstall, or unexpected termination of EDR/AV/security-agent services
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic service-state change followed by missing heartbeat for a lab endpoint

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'EDR or Security Agent Service Stopped' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-032 - Antivirus Exclusion Added

Domain	Defense Impairment & Stealth
ATT&CK	T1562.001 Impair Defenses: Disable or Modify Tools
Severity	Critical
Window	10m
Telemetry	AV/EDR configuration audit, registry/PowerShell
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256,

	signer, destination
Source Library ID	DE-062
ATT&CK v19.2 Artifact	Direct: DET0051 - Detection Strategy for File/Path Exclusions
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect addition of file, path, process, or extension exclusions, especially by unusual users or script processes - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect addition of file, path, process, or extension exclusions, especially by unusual users or script processes GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow centrally managed policy deployment; flag local exceptions with no change record
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect addition of file, path, process, or extension exclusions, especially by unusual users or script processes
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay a synthetic exclusion-add audit event for a harmless lab path

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Antivirus Exclusion Added' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-033 - Windows Security Log Cleared

Domain	Defense Impairment & Stealth
ATT&CK	T1070.001 Indicator Removal: Clear Windows Event Logs
Severity	Critical

Window	5m
Telemetry	Windows Security/System, SIEM health
Fields	timestamp, source, source_type, event_rate, last_seen, expected_rate, null_ratio, rule_id, change_actor, status
Source Library ID	DE-064
ATT&CK v19.2 Artifact	Direct: DET0532 - Detection of Event Log Clearing on Windows via Behavioral Chain
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect Event Log clear operations, especially Security or PowerShell logs, and correlate with actor/process - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect Event Log clear operations, especially Security or PowerShell logs, and correlate with actor/process GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Rare legitimate use should require documented administrative procedure
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect Event Log clear operations, especially Security or PowerShell logs, and correlate with actor/process
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Use a synthetic Event 1102-style record rather than clearing a production log

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Windows Security Log Cleared' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-034 - Critical Telemetry Disappears After Suspicious Activity

Domain	Defense Impairment & Stealth
ATT&CK	T1562.001 Impair Defenses
Severity	Critical
Window	10m
Telemetry	SIEM ingestion health, EDR heartbeat, detection timeline
Fields	timestamp, source, source_type, event_rate, last_seen, expected_rate, null_ratio, rule_id, change_actor, status
Source Library ID	DE-068
ATT&CK v19.2 Artifact	Direct/Contextual: DET0900 - Detection of Defense Impairment
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate a high-risk endpoint or identity alert with abrupt loss of telemetry from the same asset within a short interval - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate a high-risk endpoint or identity alert with abrupt loss of telemetry from the same asset within a short interval GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Differentiate planned reboot/network outage from security-control loss using infrastructure health data
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate a high-risk endpoint or identity alert with abrupt loss of telemetry from the same asset within a short interval
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay a suspicious-process alert followed by heartbeat-gap events for the same lab host

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Critical Telemetry Disappears After Suspicious Activity' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.

- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-035 - Process Masquerading - Name/Path/Signer Mismatch

Domain	Defense Impairment & Stealth
ATT&CK	T1036 Masquerading
Severity	High
Window	10m
Telemetry	EDR process, signer, hash reputation
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-070
ATT&CK v19.2 Artifact	Composite: DET0127 - Behavioral Detection of Masquerading Across Platforms via Metadata and Execution Discrepancy; DET0005 - Renamed Legitimate Utility Execution with Metadata Mismatch and Suspicious Path
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect system-like process names executing from wrong directories, Unicode lookalikes, renamed tools, or unsigned binaries mimicking trusted utilities - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect system-like process names executing from wrong directories, Unicode lookalikes, renamed tools, or unsigned binaries mimicking trusted utilities GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline portable admin tools and approved packaging; combine name, path, signer, parent, and hash
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect system-like process names executing from wrong directories, Unicode lookalikes, renamed tools, or unsigned binaries mimicking trusted utilities
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay a synthetic process event named like a system binary from a lab user-writable path

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Process Masquerading - Name/Path/Signer Mismatch' is satisfied.

- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

08. Email & Collaboration

Detect phishing, mailbox persistence, collaboration abuse, forwarding, OAuth consent, and internal propagation across modern communication channels.

ID	Rule	Severity
DE-036	Executive Impersonation With Authentication Failure	High
DE-037	Email Click to Newly Registered or Rare Domain	High
DE-038	New Mailbox Forwarding Rule	High
DE-039	OAuth Consent Granted After Phishing-Like Sign-in	Critical
DE-040	High-Volume Outbound Email After Account Anomaly	Critical

DE-036 - Executive Impersonation With Authentication Failure

Domain	Email & Collaboration
ATT&CK	T1566 Phishing
Severity	High
Window	5m
Telemetry	Email gateway, SPF/DKIM/DMARC, directory
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-071
ATT&CK v19.2 Artifact	Contextual: DET0899 - Detect Social Engineering
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect inbound mail using executive/display-name impersonation with DMARC/SPF/DKIM failure, lookalike domain, or unusual reply-to - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect inbound mail using executive/display-name impersonation with DMARC/SPF/DKIM failure, lookalike domain, or unusual reply-to GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Maintain VIP list and legitimate marketing/send-on-behalf providers; avoid blocking on display name alone
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect inbound mail using executive/display-name impersonation with DMARC/SPF/DKIM failure, lookalike domain, or unusual reply-to
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Quarantine/remove malicious messages or files from affected mailboxes/channels where supported.

- Block confirmed malicious sender/domain/URL indicators and search all recipients.
- If account compromise is suspected, revoke sessions and investigate mailbox/identity persistence.

SAFE VALIDATION

Send a harmless internal phishing-simulation message from an approved test domain with spoof-like metadata

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Executive Impersonation With Authentication Failure' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-037 - Email Click to Newly Registered or Rare Domain

Domain	Email & Collaboration
ATT&CK	T1566.002 Phishing: Spearphishing Link
Severity	High
Window	30m
Telemetry	Email click telemetry, proxy, DNS, domain age/reputation
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-074
ATT&CK v19.2 Artifact	Direct: DET0878 - Detection of Spearphishing Link
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate delivered email URL with user click to a newly registered, first-seen, or low-prevalence domain - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate delivered email URL with user click to a newly registered, first-seen, or low-prevalence domain GROUP/RELATE BY source host and queried domain WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow approved campaign platforms and vendor login domains; use domain age as context not sole verdict
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate delivered email URL with user click to a newly registered, first-seen, or low-prevalence domain
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Quarantine/remove malicious messages or files from affected mailboxes/channels where supported.
- Block confirmed malicious sender/domain/URL indicators and search all recipients.
- If account compromise is suspected, revoke sessions and investigate mailbox/identity persistence.

SAFE VALIDATION

Send a simulation link to an internal test domain marked low-prevalence in test data

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Email Click to Newly Registered or Rare Domain' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-038 - New Mailbox Forwarding Rule

Domain	Email & Collaboration
ATT&CK	T1114.003 Email Collection: Email Forwarding Rule
Severity	High
Window	10m
Telemetry	Exchange/M365 audit, mailbox settings
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-075
ATT&CK v19.2 Artifact	Direct: DET0576 - Email Forwarding Rule Abuse Detection Across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect creation or modification of automatic forwarding to external addresses or unusual internal recipients - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect creation or modification of automatic forwarding to external addresses or unusual internal recipients GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow documented shared-mailbox workflows; alert on external forward by default
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect creation or modification of automatic forwarding to external addresses or unusual internal recipients
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Quarantine/remove malicious messages or files from affected mailboxes/channels where supported.
- Block confirmed malicious sender/domain/URL indicators and search all recipients.
- If account compromise is suspected, revoke sessions and investigate mailbox/identity persistence.

SAFE VALIDATION

Create and remove a temporary forwarding rule on a dedicated lab mailbox

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'New Mailbox Forwarding Rule' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-039 - OAuth Consent Granted After Phishing-Like Sign-in

Domain	Email & Collaboration
ATT&CK	T1098 Account Manipulation; T1528 Steal Application Access Token
Severity	Critical
Window	30m
Telemetry	IdP sign-in, OAuth consent, app audit
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-077
ATT&CK v19.2 Artifact	Composite: DET0096 - Account Manipulation Behavior Chain Detection; DET0515 - Detection Strategy for T1528 - Steal Application Access Token
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate risky/new-device sign-in with consent to an application requesting high-risk mail/files/directory scopes - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate risky/new-device sign-in with consent to an application requesting high-risk mail/files/directory scopes GROUP/RELATE BY user account and source/device WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Maintain trusted application catalog and publisher verification; require admin consent for high-risk scopes where possible
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.

- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate risky/new-device sign-in with consent to an application requesting high-risk mail/files/directory scopes
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Quarantine/remove malicious messages or files from affected mailboxes/channels where supported.
- Block confirmed malicious sender/domain/URL indicators and search all recipients.
- If account compromise is suspected, revoke sessions and investigate mailbox/identity persistence.

SAFE VALIDATION

Replay synthetic risky sign-in followed by consent to a benign test application record

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'OAuth Consent Granted After Phishing-Like Sign-in' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-040 - High-Volume Outbound Email After Account Anomaly

Domain	Email & Collaboration
ATT&CK	T1534 Internal Spearphishing
Severity	Critical
Window	30m
Telemetry	M365/Exchange message trace, identity risk
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-079
ATT&CK v19.2 Artifact	Composite/Contextual: DET0560 - Detection of Valid Account Abuse Across Platforms; correlate with outbound email-volume analytics
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect sudden outbound volume, many distinct recipients, or unusual external recipients after risky sign-in or mailbox-rule change - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect sudden outbound volume, many distinct recipients, or unusual external recipients after risky sign-in or mailbox-rule change GROUP/RELATE BY user account and source/device WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved bulk-mail systems and communications teams using dedicated accounts
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.

- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect sudden outbound volume, many distinct recipients, or unusual external recipients after risky sign-in or mailbox-rule change
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Quarantine/remove malicious messages or files from affected mailboxes/channels where supported.
- Block confirmed malicious sender/domain/URL indicators and search all recipients.
- If account compromise is suspected, revoke sessions and investigate mailbox/identity persistence.

SAFE VALIDATION

Replay synthetic high-volume send records following a lab risky-sign-in event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'High-Volume Outbound Email After Account Anomaly' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

09. Network, DNS, Proxy & C2

Detect command-and-control, beaconing, suspicious DNS, rare destinations, anonymizers, and abnormal network behavior using multi-source context.

ID	Rule	Severity
DE-041	Outbound Connection to Known Malicious IP	High
DE-042	DNS Query to Known Malicious Domain	High
DE-043	DNS Tunneling Suspicion	High
DE-044	Periodic Beaconing to External Destination	High
DE-045	Suspicious Process Chain Followed by C2-Like Connection	Critical

DE-041 - Outbound Connection to Known Malicious IP

Domain	Network, DNS, Proxy & C2
ATT&CK	T1071 Application Layer Protocol; T1105 Ingress Tool Transfer
Severity	High
Window	5m
Telemetry	Firewall, proxy, EDR network, threat intel

Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-081
ATT&CK v19.2 Artifact	Contextual: IOC match is not a one-to-one ATT&CK Detection Strategy; correlate the indicator with DET0444/other current C2 strategies for the observed behavior
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - match outbound connections against high-confidence active malicious IP indicators; elevate when connection is permitted and asset is critical - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Match outbound connections against high-confidence active malicious IP indicators; elevate when connection is permitted and asset is critical GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Use indicator confidence/expiry; avoid permanent blocks for shared cloud/CDN addresses without context
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Match outbound connections against high-confidence active malicious IP indicators; elevate when connection is permitted and asset is critical
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Load a reserved documentation IP into a lab IOC list and replay a synthetic connection hit

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'Outbound Connection to Known Malicious IP'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-042 - DNS Query to Known Malicious Domain

Domain	Network, DNS, Proxy & C2
ATT&CK	T1071.004 Application Layer Protocol: DNS

Severity	High
Window	5m
Telemetry	DNS resolver, endpoint DNS, threat intel
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-082
ATT&CK v19.2 Artifact	Contextual: IOC match is not a one-to-one ATT&CK Detection Strategy; correlate DNS indicator hits with the current T1071.004 detection strategies
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - match DNS queries to active high-confidence malicious domains including normalized subdomain handling - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Match DNS queries to active high-confidence malicious domains including normalized subdomain handling GROUP/RELATE BY source host and queried domain WITHIN 5m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Apply IOC expiry, wildcard logic carefully, and exclude sinkhole/test domains
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Match DNS queries to active high-confidence malicious domains including normalized subdomain handling
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Insert a reserved .invalid domain into a test IOC collection and replay a query

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'DNS Query to Known Malicious Domain'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-043 - DNS Tunneling Suspicion

Domain	Network, DNS, Proxy & C2
ATT&CK	T1071.004 Application Layer Protocol: DNS
Severity	High
Window	15m
Telemetry	DNS resolver, NDR
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-084
ATT&CK v19.2 Artifact	Direct: DET0400 - Behavioral Detection of DNS Tunneling and Application Layer Abuse
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect long/high-entropy labels, excessive TXT queries, unusual query volume, or large response sizes to a low-prevalence domain - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect long/high-entropy labels, excessive TXT queries, unusual query volume, or large response sizes to a low-prevalence domain GROUP/RELATE BY source host and queried domain WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline legitimate DNS security, service discovery, DKIM, and cloud applications
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect long/high-entropy labels, excessive TXT queries, unusual query volume, or large response sizes to a low-prevalence domain
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Replay synthetic long-label queries to an internal test domain without transferring real data

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'DNS Tunneling Suspicion'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.

- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-044 - Periodic Beaconsing to External Destination

Domain	Network, DNS, Proxy & C2
ATT&CK	T1071 Application Layer Protocol
Severity	High
Window	1h
Telemetry	Firewall, proxy, NDR, EDR network
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-085
ATT&CK v19.2 Artifact	Contextual: DET0228 - Detect Multi-Stage Command and Control Channels; tune around periodicity, rarity, process and destination context
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect low-jitter periodic connections from one host/process to the same rare external destination over an extended period - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect low-jitter periodic connections from one host/process to the same rare external destination over an extended period
GROUP/RELATE BY user/host/source entity WITHIN 1h THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude software update, monitoring, NTP, telemetry, and heartbeat services based on process/domain
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect low-jitter periodic connections from one host/process to the same rare external destination over an extended period
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Replay synthetic flow events every 60 seconds with small jitter to a reserved test destination

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'Periodic Beaconsing to External Destination'.

- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-045 - Suspicious Process Chain Followed by C2-Like Connection

Domain	Network, DNS, Proxy & C2
ATT&CK	T1071 Application Layer Protocol; T1105 Ingress Tool Transfer
Severity	Critical
Window	15m
Telemetry	EDR process/network, DNS, proxy
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-090
ATT&CK v19.2 Artifact	Composite: DET0228 - Detect Multi-Stage Command and Control Channels; DET0444 - Detection of Command and Control Over Application Layer Protocols
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate suspicious execution such as Office-to-script or new Temp executable with a rare outbound destination within minutes - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate suspicious execution such as Office-to-script or new Temp executable with a rare outbound destination within minutes
GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Use process lineage and domain prevalence; exclude signed update workflows
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate suspicious execution such as Office-to-script or new Temp executable with a rare outbound destination within minutes
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Replay synthetic Office-to-PowerShell plus reserved-domain network events

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'Suspicious Process Chain Followed by C2-Like Connection'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

10. Web, WAF & Application

Detect exploitation and abuse of public-facing applications, APIs, administrative routes, and server-side process behavior.

ID	Rule	Severity
DE-046	Path Traversal Exploit Attempt	High
DE-047	Command Injection or Shell Metacharacter Attempt	Critical
DE-048	Web Server Process Spawns Command Shell	Critical
DE-049	New Script or Executable Created in Web Root	Critical
DE-050	Exploit Attempt Followed by Server Outbound Connection	Critical

DE-046 - Path Traversal Exploit Attempt

Domain	Web, WAF & Application
ATT&CK	T1190 Exploit Public-Facing Application
Severity	High
Window	5m
Telemetry	WAF, reverse proxy, application logs
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-093
ATT&CK v19.2 Artifact	Direct/Contextual: DET0080 - Exploit Public-Facing Application - multi-signal correlation (request -> error -> post-exploit process/egress)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect traversal encodings and path manipulation targeting sensitive files or directories, especially when followed by successful response - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect traversal encodings and path manipulation targeting sensitive files or directories, especially when followed by successful response GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Tune against legitimate encoded URLs and scanners; prioritize successful/large response combinations
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect traversal encodings and path manipulation targeting sensitive files or directories, especially when followed by successful response
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.

- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Send harmless traversal-like strings to a dedicated test endpoint that returns no sensitive data

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Path Traversal Exploit Attempt' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-047 - Command Injection or Shell Metacharacter Attempt

Domain	Web, WAF & Application
ATT&CK	T1190 Exploit Public-Facing Application; T1059 Command and Scripting Interpreter
Severity	Critical
Window	5m
Telemetry	WAF, app logs, EDR on server
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-095
ATT&CK v19.2 Artifact	Composite: DET0080 - Exploit Public-Facing Application multi-signal correlation; DET0516 - Behavioral Detection of Command and Scripting Interpreter Abuse
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect shell metacharacters/command payload patterns in web parameters and raise severity if server spawns a shell or utility - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect shell metacharacters/command payload patterns in web parameters and raise severity if server spawns a shell or utility GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude application features that legitimately accept shell syntax only with strict context
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect shell metacharacters/command payload patterns in web parameters and raise severity if server spawns a shell or utility
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.

- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.
- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Send harmless metacharacter strings to a lab endpoint and replay a benign child-process event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Command Injection or Shell Metacharacter Attempt' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-048 - Web Server Process Spawns Command Shell

Domain	Web, WAF & Application
ATT&CK	T1505.003 Server Software Component: Web Shell; T1059
Severity	Critical
Window	5m
Telemetry	EDR process, web server logs
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-096
ATT&CK v19.2 Artifact	Direct: DET0394 - Web Shell Detection via Server Behavior and File Execution Chains
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect IIS/Apache/nginx/PHP/Java application processes spawning cmd, PowerShell, bash, sh, curl, wget, certutil, or similar utilities - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect IIS/Apache/nginx/PHP/Java application processes spawning cmd, PowerShell, bash, sh, curl, wget, certutil, or similar utilities GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline approved application maintenance functions and build agents; rare on production servers
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect IIS/Apache/nginx/PHP/Java application processes spawning cmd, PowerShell, bash, sh, curl, wget, certutil, or similar utilities
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.
- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Replay synthetic parent-child process telemetry with web server as parent and benign shell as child

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Web Server Process Spawns Command Shell' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-049 - New Script or Executable Created in Web Root

Domain	Web, WAF & Application
ATT&CK	T1505.003 Server Software Component: Web Shell
Severity	Critical
Window	10m
Telemetry	File integrity, EDR file creation, deployment logs
Fields	timestamp, user, host, process_name, file_path, classification, bytes, destination, action, count
Source Library ID	DE-097
ATT&CK v19.2 Artifact	Direct: DET0394 - Web Shell Detection via Server Behavior and File Execution Chains
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect unexpected creation or modification of executable/script files in web roots outside approved deployment pipelines - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect unexpected creation or modification of executable/script files in web roots outside approved deployment pipelines
GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Integrate CI/CD deployment identities, release windows, hashes, and package manifests
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.

- Confirm the exact condition that matched: Detect unexpected creation or modification of executable/script files in web roots outside approved deployment pipelines
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.
- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Create a harmless marker script in a lab web root through the approved test process and remove it

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'New Script or Executable Created in Web Root' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-050 - Exploit Attempt Followed by Server Outbound Connection

Domain	Web, WAF & Application
ATT&CK	T1190 Exploit Public-Facing Application; T1071 Application Layer Protocol
Severity	Critical
Window	10m
Telemetry	WAF, EDR network, app logs
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-100
ATT&CK v19.2 Artifact	Composite: DET0080 - Exploit Public-Facing Application multi-signal correlation; DET0444 - Detection of Command and Control Over Application Layer Protocols
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate successful/high-confidence exploit signature with new outbound connection from the targeted server/process soon afterward - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate successful/high-confidence exploit signature with new outbound connection from the targeted server/process soon afterward GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude application callbacks/webhooks only when destination and process are expected
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.

- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate successful/high-confidence exploit signature with new outbound connection from the targeted server/process soon afterward
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.
- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Replay synthetic WAF exploit alert followed by reserved-destination server connection

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Exploit Attempt Followed by Server Outbound Connection' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

11. Cloud IaaS

Detect cloud-account compromise, privilege escalation, logging impairment, exposure changes, and suspicious storage access across cloud control planes.

ID	Rule	Severity
DE-051	Cloud Console Login From New Geo or Device	High
DE-052	New Access Key Created for Dormant User	High
DE-053	Administrative IAM Policy or Role Granted	Critical
DE-054	Cloud Audit Logging Disabled or Reduced	Critical
DE-055	Mass Object Download From Cloud Storage	High

DE-051 - Cloud Console Login From New Geo or Device

Domain	Cloud IaaS
ATT&CK	T1078.004 Valid Accounts: Cloud Accounts
Severity	High
Window	30m
Telemetry	Cloud audit, IdP, device/risk data
Fields	timestamp, principal, source_ip, session_id, action, resource, region, result, user_agent, device_id
Source Library ID	DE-101
ATT&CK v19.2 Artifact	Direct: DET0008 - Behavioral Detection of Remote Cloud Logins via Valid Accounts
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect console sign-in from new country/ASN/device for privileged or sensitive cloud identity - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect console sign-in from new country/ASN/device for privileged or sensitive cloud identity GROUP/RELATE BY user account and source/device WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude corporate VPN and approved travel; prefer device/session continuity and peer behavior
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect console sign-in from new country/ASN/device for privileged or sensitive cloud identity
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic cloud sign-ins from a new test ASN/device for a lab identity

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Cloud Console Login From New Geo or Device' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-052 - New Access Key Created for Dormant User

Domain	Cloud IaaS
ATT&CK	T1098.001 Account Manipulation: Additional Cloud Credentials
Severity	High
Window	30m
Telemetry	Cloud IAM audit
Fields	timestamp, principal, source_ip, session_id, action, resource, region, result, user_agent, device_id
Source Library ID	DE-103
ATT&CK v19.2 Artifact	Direct: DET0531 - Detection Strategy for Additional Cloud Credentials in IaaS/IdP/SaaS
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect new access key/API credential for identity dormant or rarely used, especially followed by API activity - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect new access key/API credential for identity dormant or rarely used, especially followed by API activity GROUP/RELATE BY principal/session/resource WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude automated credential rotation for active service accounts; correlate with owner and ticket
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect new access key/API credential for identity dormant or rarely used, especially followed by API activity
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic access-key creation for a dormant lab user followed by benign list API call

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'New Access Key Created for Dormant User' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-053 - Administrative IAM Policy or Role Granted

Domain	Cloud IaaS
ATT&CK	T1098.003 Account Manipulation: Additional Cloud Roles
Severity	Critical
Window	10m
Telemetry	Cloud IAM audit
Fields	timestamp, principal, source_ip, session_id, action, resource, region, result, user_agent, device_id
Source Library ID	DE-104
ATT&CK v19.2 Artifact	Contextual: DET0096 - Account Manipulation Behavior Chain Detection; select current cloud-role analytics for the target provider
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect attachment/creation of administrator-level policy, role binding, or broad wildcard permission by unusual actor - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect attachment/creation of administrator-level policy, role binding, or broad wildcard permission by unusual actor GROUP/RELATE BY principal/session/resource WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Integrate IaC deployment identities, change pipeline, and approved break-glass roles
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect attachment/creation of administrator-level policy, role binding, or broad wildcard permission by unusual actor
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic role/policy grant in a sandbox account

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Administrative IAM Policy or Role Granted' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-054 - Cloud Audit Logging Disabled or Reduced

Domain	Cloud IaaS
ATT&CK	T1562.008 Impair Defenses: Disable or Modify Cloud Logs
Severity	Critical
Window	5m
Telemetry	Cloud control-plane audit
Fields	timestamp, principal, source_ip, session_id, action, resource, region, result, user_agent, device_id
Source Library ID	DE-106
ATT&CK v19.2 Artifact	Direct/Contextual: DET0900 - Detection of Defense Impairment (includes IaaS logging/security-service degradation analytics)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect stop/delete/update of audit trails, diagnostic settings, event routing, retention, or logging destinations - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect stop/delete/update of audit trails, diagnostic settings, event routing, retention, or logging destinations GROUP/RELATE BY principal/session/resource WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow only centralized security/IaC roles and approved changes; verify independent log copy
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect stop/delete/update of audit trails, diagnostic settings, event routing, retention, or logging destinations
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic audit-configuration change in a sandbox or test stream

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Cloud Audit Logging Disabled or Reduced' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-055 - Mass Object Download From Cloud Storage

Domain	Cloud IaaS
ATT&CK	T1530 Data from Cloud Storage
Severity	High
Window	30m
Telemetry	Object-storage access logs, IAM, DLP
Fields	timestamp, principal, source_ip, session_id, action, resource, region, result, user_agent, device_id
Source Library ID	DE-109
ATT&CK v19.2 Artifact	Direct/Contextual: Use current cloud-storage collection analytics; pair with DET0578 for storage-object discovery and exfiltration strategies if transfer follows
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect one principal downloading unusually high numbers or bytes of sensitive objects, especially from new location/device - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect one principal downloading unusually high numbers or bytes of sensitive objects, especially from new location/device GROUP/RELATE BY principal/session/resource WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline backup, analytics, data science, and migration jobs; use data classification
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.

- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect one principal downloading unusually high numbers or bytes of sensitive objects, especially from new location/device
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic object GET events against dummy data in a sandbox bucket/container

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Mass Object Download From Cloud Storage' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

12. SaaS, M365 & OAuth

Detect token/app abuse, mailbox manipulation, high-risk consent, SaaS privilege changes, and abnormal information access.

ID	Rule	Severity
DE-056	Risky Sign-in Followed by Inbox Rule Creation	Critical
DE-057	Impossible Travel in SaaS Account	High
DE-058	OAuth Consent to High-Risk Permissions	Critical
DE-059	New MFA Device Registered After Unusual Session	Critical
DE-060	Mass SharePoint or OneDrive Download	High

DE-056 - Risky Sign-in Followed by Inbox Rule Creation

Domain	SaaS, M365 & OAuth
ATT&CK	T1078 Valid Accounts; T1114.003 Email Forwarding Rule
Severity	Critical
Window	30m
Telemetry	Entra/IdP, Exchange audit
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-111
ATT&CK v19.2 Artifact	Composite: DET0560 - Detection of Valid Account Abuse Across Platforms; DET0576 - Email Forwarding Rule Abuse Detection Across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate risky/new-device sign-in with creation of a forwarding, delete, or move inbox rule - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate risky/new-device sign-in with creation of a forwarding, delete, or move inbox rule GROUP/RELATE BY user account and source/device WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude onboarding and mailbox migration workflows; require both identity and mailbox signals
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate risky/new-device sign-in with creation of a forwarding, delete, or move inbox rule
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic risky sign-in plus rule-creation events for a lab mailbox

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Risky Sign-in Followed by Inbox Rule Creation' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-057 - Impossible Travel in SaaS Account

Domain	SaaS, M365 & OAuth
ATT&CK	T1078 Valid Accounts
Severity	High
Window	2h
Telemetry	SaaS sign-in, IdP risk
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-112
ATT&CK v19.2 Artifact	Direct/Contextual: DET0560 - Detection of Valid Account Abuse Across Platforms

Artifact Trace

Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect successful SaaS sessions from geographically incompatible locations with different device/session characteristics - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect successful SaaS sessions from geographically incompatible locations with different device/session characteristics GROUP/RELATE BY user account and source/device WITHIN 2h THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude corporate VPN egress and mobile carrier geolocation anomalies
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect successful SaaS sessions from geographically incompatible locations with different device/session characteristics
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay two synthetic successful sign-ins from distant test geographies

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Impossible Travel in SaaS Account' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-058 - OAuth Consent to High-Risk Permissions

Domain	SaaS, M365 & OAuth
ATT&CK	T1528 Steal Application Access Token; T1098 Account Manipulation
Severity	Critical
Window	10m
Telemetry	OAuth consent, app registration, IdP

Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-113
ATT&CK v19.2 Artifact	Composite: DET0515 - Detection Strategy for T1528 - Steal Application Access Token; DET0096 - Account Manipulation Behavior Chain Detection
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect user/admin consent to apps requesting Mail.ReadWrite, Files.Read.All, offline_access, Directory.ReadWrite, or equivalent high-impact scopes - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect user/admin consent to apps requesting Mail.ReadWrite, Files.Read.All, offline_access, Directory.ReadWrite, or equivalent high-impact scopes GROUP/RELATE BY principal/session/resource WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Maintain trusted app catalog, verified publishers, and approved scopes
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect user/admin consent to apps requesting Mail.ReadWrite, Files.Read.All, offline_access, Directory.ReadWrite, or equivalent high-impact scopes
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay consent to a benign lab application record with simulated high-risk scopes

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'OAuth Consent to High-Risk Permissions' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-059 - New MFA Device Registered After Unusual Session

Domain	SaaS, M365 & OAuth
ATT&CK	T1098 Account Manipulation

Severity	Critical
Window	30m
Telemetry	IdP sign-in and authentication-method audit
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-115
ATT&CK v19.2 Artifact	Direct: DET0036 - Suspicious Device Registration via Entra ID or MFA Platform
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate unfamiliar/risky session with new phone, authenticator, FIDO key, or passwordless method - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate unfamiliar/risky session with new phone, authenticator, FIDO key, or passwordless method GROUP/RELATE BY user account and source/device WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved account recovery and onboarding workflows; notify user out-of-band
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate unfamiliar/risky session with new phone, authenticator, FIDO key, or passwordless method
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic new-device sign-in and authentication-method registration events

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'New MFA Device Registered After Unusual Session' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-060 - Mass SharePoint or OneDrive Download

Domain	SaaS, M365 & OAuth
ATT&CK	T1213.002 Data from Information Repositories: SharePoint
Severity	High
Window	30m
Telemetry	M365 audit, DLP, identity
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-116
ATT&CK v19.2 Artifact	Direct: DET0500 - Detecting Abnormal SharePoint Data Mining by Privileged or Rare Users
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect user or app downloading a large number/volume of files compared with baseline, especially sensitive sites and new devices - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect user or app downloading a large number/volume of files compared with baseline, especially sensitive sites and new devices GROUP/RELATE BY principal/session/resource WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline synchronization clients, migrations, backup, legal, and data science workflows
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect user or app downloading a large number/volume of files compared with baseline, especially sensitive sites and new devices
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious sessions/tokens where appropriate; restrict or disable the affected identity according to IR policy.
- Review and reverse unauthorized MFA, role, group, credential, delegate, or application-consent changes.
- Search for reuse of the same identity/session across additional services and devices.

SAFE VALIDATION

Replay synthetic file-download audit events against dummy library data

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 09:12 - Authentication/audit activity begins for the test identity.
- 09:16 - The condition for 'Mass SharePoint or OneDrive Download' is observed.
- 09:18 - SIEM enriches the event with privilege, device, source, and recent activity; analyst reviews the timeline.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.

- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

13. Containers & Kubernetes

Detect risky container administration, privileged workloads, secret access, RBAC abuse, control-plane logging changes, and runtime anomalies.

ID	Rule	Severity
DE-061	Unusual kubect exec Into Running Pod	High
DE-062	Privileged Pod or Container Created	Critical
DE-063	Cluster-Admin Role Binding Created	Critical
DE-064	Kubernetes Audit Logging Disabled or Sink Changed	Critical
DE-065	Burst of Secret Enumeration	Critical

DE-061 - Unusual kubect exec Into Running Pod

Domain	Containers & Kubernetes
ATT&CK	T1609 Container Administration Command
Severity	High
Window	10m
Telemetry	Kubernetes audit, IAM
Fields	timestamp, user, service_account, verb, resource, namespace, pod, image, source_ip, result
Source Library ID	DE-121
ATT&CK v19.2 Artifact	Direct: DET0083 - Container CLI and API Abuse via Docker/Kubernetes (T1059.013)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect exec/attach into pods by users or service accounts not normally administering workloads, especially production namespaces - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect exec/attach into pods by users or service accounts not normally administering workloads, especially production namespaces GROUP/RELATE BY user/service account/namespace/workload WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline SRE/admin groups, break-glass access, and automation; require namespace criticality
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect exec/attach into pods by users or service accounts not normally administering workloads, especially production namespaces
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Quarantine or stop the affected workload/pod when justified; preserve audit/runtime evidence.
- Revoke exposed service-account tokens and remove unauthorized RBAC or workload configuration.
- Search the cluster for related images, secrets access, and control-plane changes.

SAFE VALIDATION

Perform an approved kubectl exec that only prints a marker in a lab namespace

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Unusual kubectl exec Into Running Pod' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-062 - Privileged Pod or Container Created

Domain	Containers & Kubernetes
ATT&CK	T1610 Deploy Container; T1611 Escape to Host
Severity	Critical
Window	5m
Telemetry	Kubernetes audit, admission controller
Fields	timestamp, user, service_account, verb, resource, namespace, pod, image, source_ip, result
Source Library ID	DE-122
ATT&CK v19.2 Artifact	Direct/Contextual: DET0249 - Behavior-chain detection for T1610 Deploy Container across Docker & Kubernetes control/node planes
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect pod creation with privileged=true, hostPID, hostNetwork, hostIPC, dangerous capabilities, or broad device access - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect pod creation with privileged=true, hostPID, hostNetwork, hostIPC, dangerous capabilities, or broad device access GROUP/RELATE BY user/service account/namespace/workload WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow tightly controlled infrastructure namespaces and signed deployment pipelines
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect pod creation with privileged=true, hostPID, hostNetwork, hostIPC, dangerous capabilities, or broad device access
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Quarantine or stop the affected workload/pod when justified; preserve audit/runtime evidence.
- Revoke exposed service-account tokens and remove unauthorized RBAC or workload configuration.
- Search the cluster for related images, secrets access, and control-plane changes.

SAFE VALIDATION

Deploy a harmless privileged test pod only in an isolated lab cluster and remove it immediately

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Privileged Pod or Container Created' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-063 - Cluster-Admin Role Binding Created

Domain	Containers & Kubernetes
ATT&CK	T1098 Account Manipulation
Severity	Critical
Window	5m
Telemetry	Kubernetes audit, RBAC
Fields	timestamp, user, service_account, verb, resource, namespace, pod, image, source_ip, result
Source Library ID	DE-124
ATT&CK v19.2 Artifact	Direct: DET0572 - Suspicious RoleBinding or ClusterRoleBinding Assignment in Kubernetes
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect ClusterRoleBinding/RoleBinding granting cluster-admin or equivalent broad permissions to new users/service accounts - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect ClusterRoleBinding/RoleBinding granting cluster-admin or equivalent broad permissions to new users/service accounts GROUP/RELATE BY user/service account/namespace/workload WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline deployment controllers and break-glass roles; require ticket/approval
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.

- Confirm the exact condition that matched: Detect ClusterRoleBinding/RoleBinding granting cluster-admin or equivalent broad permissions to new users/service accounts
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Quarantine or stop the affected workload/pod when justified; preserve audit/runtime evidence.
- Revoke exposed service-account tokens and remove unauthorized RBAC or workload configuration.
- Search the cluster for related images, secrets access, and control-plane changes.

SAFE VALIDATION

Create and remove a temporary lab role binding to a non-production test identity

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Cluster-Admin Role Binding Created' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-064 - Kubernetes Audit Logging Disabled or Sink Changed

Domain	Containers & Kubernetes
ATT&CK	T1562.008 Impair Defenses: Disable or Modify Cloud Logs
Severity	Critical
Window	5m
Telemetry	Kubernetes control-plane audit/config
Fields	timestamp, user, service_account, verb, resource, namespace, pod, image, source_ip, result
Source Library ID	DE-128
ATT&CK v19.2 Artifact	Direct/Contextual: DET0900 - Detection of Defense Impairment; use cloud/container audit-log impairment analytics applicable to the platform
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect changes reducing audit policy, redirecting audit sink, disabling managed control-plane logging, or lowering retention - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect changes reducing audit policy, redirecting audit sink, disabling managed control-plane logging, or lowering retention GROUP/RELATE BY user/service account/namespace/workload WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow only cluster security/IaC identities with approved change
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect changes reducing audit policy, redirecting audit sink, disabling managed control-plane logging, or lowering retention
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Quarantine or stop the affected workload/pod when justified; preserve audit/runtime evidence.
- Revoke exposed service-account tokens and remove unauthorized RBAC or workload configuration.
- Search the cluster for related images, secrets access, and control-plane changes.

SAFE VALIDATION

Replay synthetic control-plane logging-configuration change event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Kubernetes Audit Logging Disabled or Sink Changed' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-065 - Burst of Secret Enumeration

Domain	Containers & Kubernetes
ATT&CK	T1613 Container and Resource Discovery
Severity	Critical
Window	10m
Telemetry	Kubernetes audit
Fields	timestamp, user, service_account, verb, resource, namespace, pod, image, source_ip, result
Source Library ID	DE-129
ATT&CK v19.2 Artifact	Direct: DET0490 - Detection Strategy for Container and Resource Discovery
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect one user/service account listing/getting secrets across many namespaces or secret names in a short period - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect one user/service account listing/getting secrets across many namespaces or secret names in a short period GROUP/RELATE BY user/service account/namespace/workload WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline controllers and secret-management operators; group by service account and namespace
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.

- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect one user/service account listing/getting secrets across many namespaces or secret names in a short period
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Quarantine or stop the affected workload/pod when justified; preserve audit/runtime evidence.
- Revoke exposed service-account tokens and remove unauthorized RBAC or workload configuration.
- Search the cluster for related images, secrets access, and control-plane changes.

SAFE VALIDATION

Replay synthetic read-only secret-list audit records using fake secret objects in lab

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Burst of Secret Enumeration' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

14. DevOps, CI/CD & Source Control

Protect source, build, release, secrets, runners, and software supply-chain pathways from account compromise or pipeline tampering.

ID	Rule	Severity
DE-066	New Device Login Followed by Mass Repository Clone	High
DE-067	New Personal Access Token After Risky Sign-in	Critical
DE-068	Workflow or Pipeline Definition Modified Outside Release Process	Critical
DE-069	Unexpected CI Runner or Agent Registered	Critical
DE-070	Release Artifact Published by Unusual Identity or Pipeline	Critical

DE-066 - New Device Login Followed by Mass Repository Clone

Domain	DevOps, CI/CD & Source Control
ATT&CK	T1078 Valid Accounts
Severity	High
Window	30m

Telemetry	Git provider audit, IdP, device info
Fields	timestamp, user, repo, action, branch, runner, workflow, artifact, source_ip, result
Source Library ID	DE-131
ATT&CK v19.2 Artifact	Direct: DET0263 - Detecting Bulk or Anomalous Access to Private Code Repositories via SaaS Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate new/unfamiliar sign-in with cloning or fetching many repositories in a short interval - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate new/unfamiliar sign-in with cloning or fetching many repositories in a short interval GROUP/RELATE BY user account and source/device WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline build mirrors, backup systems, and developer workstation replacements
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate new/unfamiliar sign-in with cloning or fetching many repositories in a short interval
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Revoke suspicious developer/PAT/runner credentials and protect release/signing secrets.
- Pause affected pipeline/release if integrity cannot be established.
- Review commits, workflow changes, artifacts, dependencies, and downstream deployments for tampering.

SAFE VALIDATION

Replay synthetic new-device login plus clone events for several lab repositories

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'New Device Login Followed by Mass Repository Clone' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-067 - New Personal Access Token After Risky Sign-in

Domain	DevOps, CI/CD & Source Control
ATT&CK	T1098.001 Additional Cloud Credentials
Severity	Critical

Window	30m
Telemetry	Git provider audit, IdP
Fields	timestamp, user, repo, action, branch, runner, workflow, artifact, source_ip, result
Source Library ID	DE-132
ATT&CK v19.2 Artifact	Direct/Contextual: DET0531 - Detection Strategy for Additional Cloud Credentials in IaaS/IdP/SaaS
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate risky sign-in with creation of PAT/API token/SSH key for the same developer identity - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate risky sign-in with creation of PAT/API token/SSH key for the same developer identity GROUP/RELATE BY user account and source/device WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow approved token-rotation workflows and short-lived tokens; enforce expiration
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate risky sign-in with creation of PAT/API token/SSH key for the same developer identity
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious developer/PAT/runner credentials and protect release/signing secrets.
- Pause affected pipeline/release if integrity cannot be established.
- Review commits, workflow changes, artifacts, dependencies, and downstream deployments for tampering.

SAFE VALIDATION

Replay synthetic risky login and PAT creation for a lab developer

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'New Personal Access Token After Risky Sign-in' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-068 - Workflow or Pipeline Definition Modified Outside Release Process

Domain	DevOps, CI/CD & Source Control
ATT&CK	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain

Severity	Critical
Window	15m
Telemetry	Git commit/audit, CI/CD logs
Fields	timestamp, user, repo, action, branch, runner, workflow, artifact, source_ip, result
Source Library ID	DE-134
ATT&CK v19.2 Artifact	Direct: DET0537 - Behavioral detection for Supply Chain Compromise (package/update tamper -> install -> first-run)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect changes to workflow YAML, pipeline scripts, buildspec, release jobs, or signing steps by unusual identity or outside approved branch/review process - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect changes to workflow YAML, pipeline scripts, buildspec, release jobs, or signing steps by unusual identity or outside approved branch/review process GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Integrate protected branches, code-owner review, signed commits, and change tickets
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect changes to workflow YAML, pipeline scripts, buildspec, release jobs, or signing steps by unusual identity or outside approved branch/review process
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious developer/PAT/runner credentials and protect release/signing secrets.
- Pause affected pipeline/release if integrity cannot be established.
- Review commits, workflow changes, artifacts, dependencies, and downstream deployments for tampering.

SAFE VALIDATION

Commit a harmless comment change to a lab pipeline file through an intentionally unapproved test branch

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Workflow or Pipeline Definition Modified Outside Release Process' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-069 - Unexpected CI Runner or Agent Registered

Domain	DevOps, CI/CD & Source Control
ATT&CK	T1195.002 Compromise Software Supply Chain
Severity	Critical
Window	10m
Telemetry	CI/CD admin audit
Fields	timestamp, user, repo, action, branch, runner, workflow, artifact, source_ip, result
Source Library ID	DE-135
ATT&CK v19.2 Artifact	Direct/Contextual: DET0537 - Behavioral detection for Supply Chain Compromise; correlate runner registration with workflow/repository changes
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect registration of new self-hosted runner/agent, changed labels, or runner attached to sensitive project by unusual admin - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect registration of new self-hosted runner/agent, changed labels, or runner attached to sensitive project by unusual admin GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Maintain approved runner inventory and IaC ownership; require attestation where available
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect registration of new self-hosted runner/agent, changed labels, or runner attached to sensitive project by unusual admin
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious developer/PAT/runner credentials and protect release/signing secrets.
- Pause affected pipeline/release if integrity cannot be established.
- Review commits, workflow changes, artifacts, dependencies, and downstream deployments for tampering.

SAFE VALIDATION

Replay synthetic runner-registration audit record for a lab project

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Unexpected CI Runner or Agent Registered' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.

- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-070 - Release Artifact Published by Unusual Identity or Pipeline

Domain	DevOps, CI/CD & Source Control
ATT&CK	T1195.002 Compromise Software Supply Chain
Severity	Critical
Window	15m
Telemetry	Artifact registry, CI/CD, code signing
Fields	timestamp, user, repo, action, branch, runner, workflow, artifact, source_ip, result
Source Library ID	DE-140
ATT&CK v19.2 Artifact	Direct/Contextual: DET0537 - Behavioral detection for Supply Chain Compromise; DET0309 - Compromised software/update chain
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect production package/release publish from new identity, new runner, unapproved branch, missing signature, or unusual artifact hash lineage - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect production package/release publish from new identity, new runner, unapproved branch, missing signature, or unusual artifact hash lineage GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline release service accounts, signed pipelines, and approved registries
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect production package/release publish from new identity, new runner, unapproved branch, missing signature, or unusual artifact hash lineage
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Revoke suspicious developer/PAT/runner credentials and protect release/signing secrets.
- Pause affected pipeline/release if integrity cannot be established.
- Review commits, workflow changes, artifacts, dependencies, and downstream deployments for tampering.

SAFE VALIDATION

Publish a harmless test package to a lab registry using a designated test identity

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Release Artifact Published by Unusual Identity or Pipeline' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

15. Collection & Exfiltration

Detect data gathering, staging, archiving, removable-media transfer, web/cloud uploads, and abnormal bulk access before sensitive information leaves the environment.

ID	Rule	Severity
DE-071	Abnormal Sensitive File Read Volume	High
DE-072	Archive Utility After Mass File Access	High
DE-073	Large Outbound Upload to New Domain	Critical
DE-074	Upload to Personal Cloud Storage	High
DE-075	DNS-Based Exfiltration Pattern	Critical

DE-071 - Abnormal Sensitive File Read Volume

Domain	Collection & Exfiltration
ATT&CK	T1005 Data from Local System
Severity	High
Window	30m
Telemetry	EDR file access, DLP, file server audit
Fields	timestamp, user, host, process_name, file_path, classification, bytes, destination, action, count
Source Library ID	DE-141
ATT&CK v19.2 Artifact	Direct: DET0380 - Detection of Local Data Collection Prior to Exfiltration
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect one user/process reading many sensitive files or bytes compared with baseline in a short period - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect one user/process reading many sensitive files or bytes compared with baseline in a short period GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline backup, indexing, legal, migration, and analytics jobs; use data classification
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect one user/process reading many sensitive files or bytes compared with baseline in a short period
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Stop or restrict the active transfer if policy and business impact allow.
- Identify exactly what data was accessed, staged, archived, or transmitted and its classification.
- Preserve endpoint/network/DLP evidence and initiate data-breach assessment where appropriate.

SAFE VALIDATION

Replay synthetic read events against dummy classified files

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Abnormal Sensitive File Read Volume' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-072 - Archive Utility After Mass File Access

Domain	Collection & Exfiltration
ATT&CK	T1560.001 Archive Collected Data: Archive via Utility
Severity	High
Window	15m
Telemetry	EDR process/file, DLP
Fields	timestamp, user, host, process_name, file_path, classification, bytes, destination, action, count
Source Library ID	DE-142
ATT&CK v19.2 Artifact	Direct: DET0298 - Detect Archiving via Utility (T1560.001)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate high-volume file reads with 7zip, rar, tar, zip, PowerShell compression, or similar archive creation by same user/process tree - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate high-volume file reads with 7zip, rar, tar, zip, PowerShell compression, or similar archive creation by same user/process tree GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline software packaging and backup processes; raise severity for sensitive directories
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate high-volume file reads with 7zip, rar, tar, zip, PowerShell compression, or similar archive creation by same user/process tree
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.

- Stop or restrict the active transfer if policy and business impact allow.
- Identify exactly what data was accessed, staged, archived, or transmitted and its classification.
- Preserve endpoint/network/DLP evidence and initiate data-breach assessment where appropriate.

SAFE VALIDATION

Create a small archive of dummy lab files after replaying synthetic mass-read events

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Archive Utility After Mass File Access' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-073 - Large Outbound Upload to New Domain

Domain	Collection & Exfiltration
ATT&CK	T1041 Exfiltration Over C2 Channel
Severity	Critical
Window	30m
Telemetry	Proxy, firewall, NDR, endpoint process
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-145
ATT&CK v19.2 Artifact	Direct: DET0348 - Detection Strategy for Exfiltration Over C2 Channel
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect large outbound byte volume to first-seen/rare external domain from host/user not normally uploading there - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect large outbound byte volume to first-seen/rare external domain from host/user not normally uploading there GROUP/RELATE BY source host and queried domain WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline sanctioned SaaS, backups, software distribution, and vendor transfers; combine with data sensitivity
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect large outbound byte volume to first-seen/rare external domain from host/user not normally uploading there
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.

- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Stop or restrict the active transfer if policy and business impact allow.
- Identify exactly what data was accessed, staged, archived, or transmitted and its classification.
- Preserve endpoint/network/DLP evidence and initiate data-breach assessment where appropriate.

SAFE VALIDATION

Replay synthetic upload bytes to a reserved .invalid domain from a lab host

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Large Outbound Upload to New Domain' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-074 - Upload to Personal Cloud Storage

Domain	Collection & Exfiltration
ATT&CK	T1567.002 Exfiltration Over Web Service: Exfiltration to Cloud Storage
Severity	High
Window	30m
Telemetry	Proxy/CASB/DLP, endpoint
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-146
ATT&CK v19.2 Artifact	Direct: DET0570 - Detection Strategy for Exfiltration to Cloud Storage
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect sensitive file uploads to unsanctioned personal storage providers or personal tenant/account from corporate endpoint - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect sensitive file uploads to unsanctioned personal storage providers or personal tenant/account from corporate endpoint
GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Maintain sanctioned/unsanctioned app catalog and business exceptions
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect sensitive file uploads to unsanctioned personal storage providers or personal tenant/account from corporate endpoint
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Stop or restrict the active transfer if policy and business impact allow.
- Identify exactly what data was accessed, staged, archived, or transmitted and its classification.
- Preserve endpoint/network/DLP evidence and initiate data-breach assessment where appropriate.

SAFE VALIDATION

Replay synthetic CASB upload event for dummy data to a test unsanctioned app label

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Upload to Personal Cloud Storage' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-075 - DNS-Based Exfiltration Pattern

Domain	Collection & Exfiltration
ATT&CK	T1048.003 Exfiltration Over Alternative Protocol: Exfiltration Over Unencrypted Non-C2 Protocol
Severity	Critical
Window	15m
Telemetry	DNS resolver, NDR
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-148
ATT&CK v19.2 Artifact	Composite: DET0131 - Behavioral Detection Strategy for Exfiltration Over Alternative Protocol; DET0400 - Behavioral Detection of DNS Tunneling and Application Layer Abuse
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect sustained high-volume queries with long/high-entropy labels encoding data to a low-prevalence domain - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect sustained high-volume queries with long/high-entropy labels encoding data to a low-prevalence domain GROUP/RELATE BY source host and queried domain WITHIN 15m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline legitimate telemetry, DKIM, anti-spam, and service discovery; require sustained pattern
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.

- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect sustained high-volume queries with long/high-entropy labels encoding data to a low-prevalence domain
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Stop or restrict the active transfer if policy and business impact allow.
- Identify exactly what data was accessed, staged, archived, or transmitted and its classification.
- Preserve endpoint/network/DLP evidence and initiate data-breach assessment where appropriate.

SAFE VALIDATION

Replay synthetic long-label queries carrying dummy text to an internal test domain

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'DNS-Based Exfiltration Pattern' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

16. Ransomware & Impact

Detect pre-impact and destructive behaviors such as recovery inhibition, mass file modification, service stops, policy abuse, and disk wiping.

ID	Rule	Severity
DE-076	Shadow Copy or Restore Point Deletion	Critical
DE-077	Backup Service Stopped or Disabled	Critical
DE-078	High-Rate File Rename/Write Burst With New Extensions	Critical
DE-079	Group Policy Modified for Broad Execution	Critical
DE-080	Burst of Security/Database/Application Service Stops	Critical

DE-076 - Shadow Copy or Restore Point Deletion

Domain	Ransomware & Impact
ATT&CK	T1490 Inhibit System Recovery
Severity	Critical
Window	5m
Telemetry	EDR process, Windows events
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-151
ATT&CK v19.2 Artifact	Direct: DET0329 - Behavioral Detection for T1490 - Inhibit System Recovery
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise

log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect vssadmin, wmic, PowerShell, or API activity deleting shadow copies/restore points, especially outside backup maintenance - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect vssadmin, wmic, PowerShell, or API activity deleting shadow copies/restore points, especially outside backup maintenance GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow only backup/DR tools on approved hosts and windows; correlate with suspicious process lineage
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect vssadmin, wmic, PowerShell, or API activity deleting shadow copies/restore points, especially outside backup maintenance
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic shadow-copy deletion command telemetry in a lab stream

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Shadow Copy or Restore Point Deletion' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-077 - Backup Service Stopped or Disabled

Domain	Ransomware & Impact
ATT&CK	T1490 Inhibit System Recovery; T1489 Service Stop
Severity	Critical
Window	5m
Telemetry	Service audit, backup platform, EDR
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256,

	signer, destination
Source Library ID	DE-152
ATT&CK v19.2 Artifact	Composite: DET0329 - Behavioral Detection for T1490 - Inhibit System Recovery; DET0021 - Behavioral Detection for Service Stop across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect stop/disable of backup agents, snapshot services, VSS-related services, or backup schedulers by unusual actor - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect stop/disable of backup agents, snapshot services, VSS-related services, or backup schedulers by unusual actor GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Integrate approved maintenance windows and backup platform changes
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect stop/disable of backup agents, snapshot services, VSS-related services, or backup schedulers by unusual actor
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic backup-service stop event for a lab host

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Backup Service Stopped or Disabled' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-078 - High-Rate File Rename/Write Burst With New Extensions

Domain	Ransomware & Impact
ATT&CK	T1486 Data Encrypted for Impact

Severity	Critical
Window	2m
Telemetry	EDR file behavior, file server audit
Fields	timestamp, user, host, process_name, file_path, classification, bytes, destination, action, count
Source Library ID	DE-154
ATT&CK v19.2 Artifact	Direct: DET0215 - Detection of Multi-Platform File Encryption for Impact
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect one process rapidly modifying/renaming many files, high entropy changes, or consistent new extension across directories/shares - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect one process rapidly modifying/renaming many files, high entropy changes, or consistent new extension across directories/shares GROUP/RELATE BY user/host/source entity WITHIN 2m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude backup, compression, sync, encryption, and software deployment processes by signer and path
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect one process rapidly modifying/renaming many files, high entropy changes, or consistent new extension across directories/shares
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Use a lab script that renames and rewrites dummy files only inside an isolated test directory

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'High-Rate File Rename/Write Burst With New Extensions' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-079 - Group Policy Modified for Broad Execution

Domain	Ransomware & Impact
ATT&CK	T1484.001 Domain Policy Modification: Group Policy Modification
Severity	Critical
Window	10m
Telemetry	AD/GPO audit
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-157
ATT&CK v19.2 Artifact	Direct: DET0305 - Detection of Group Policy Modifications via AD Object Changes and File Activity
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect GPO changes that add startup scripts, scheduled tasks, services, security weakening, or software deployment to broad OUs/domains - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect GPO changes that add startup scripts, scheduled tasks, services, security weakening, or software deployment to broad OUs/domains GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow approved GPO admins only with change ticket; compare exact settings before/after
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect GPO changes that add startup scripts, scheduled tasks, services, security weakening, or software deployment to broad OUs/domains
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic GPO modification records in a lab domain

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Group Policy Modified for Broad Execution' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.

- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-080 - Burst of Security/Database/Application Service Stops

Domain	Ransomware & Impact
ATT&CK	T1489 Service Stop
Severity	Critical
Window	5m
Telemetry	Windows/Linux service audit, EDR
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-159
ATT&CK v19.2 Artifact	Direct: DET0021 - Behavioral Detection for Service Stop across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect one actor/process stopping many services associated with databases, backups, EDR, mail, virtualization, or business apps - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect one actor/process stopping many services associated with databases, backups, EDR, mail, virtualization, or business apps
GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow approved maintenance orchestrators during change windows; require service criticality context
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect one actor/process stopping many services associated with databases, backups, EDR, mail, virtualization, or business apps
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Isolate the affected endpoint/server if continued attacker execution is plausible.
- Terminate/quarantine malicious processes or files through approved EDR response procedures.
- Rotate exposed credentials and check nearby hosts for the same artifacts or behavior.

SAFE VALIDATION

Replay synthetic multi-service stop events in lab telemetry

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Burst of Security/Database/Application Service Stops' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

17. Threat Intelligence & IOC

Operationalize IOCs with confidence, expiry, enrichment, correlation, and behavioral follow-up rather than treating feeds as permanent blocklists.

ID	Rule	Severity
DE-081	Outbound High-Confidence Malicious IP Hit	High
DE-082	Malicious Domain DNS Match	High
DE-083	Malicious File Hash Observed on Endpoint	Critical
DE-084	Same IOC Observed Across Multiple Hosts	Critical
DE-085	IOC Hit Followed by Suspicious Behaviour	Critical

DE-081 - Outbound High-Confidence Malicious IP Hit

Domain	Threat Intelligence & IOC
ATT&CK	T1071 Application Layer Protocol
Severity	High
Window	5m
Telemetry	Threat intel, firewall, proxy, EDR
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-161
ATT&CK v19.2 Artifact	Contextual: IOC match is an intelligence artifact, not a one-to-one ATT&CK DET; correlate with the current DET for the behavior the destination supports
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - match permitted outbound traffic to active high-confidence malicious IP; enrich with asset/user/process and IOC age - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Match permitted outbound traffic to active high-confidence malicious IP; enrich with asset/user/process and IOC age GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Expire stale IOCs; avoid automatic blocking of shared infrastructure without context
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Match permitted outbound traffic to active high-confidence malicious IP; enrich with asset/user/process and IOC age
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Use RFC 5737 documentation IP in a test IOC list and replay a connection event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'Outbound High-Confidence Malicious IP Hit'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-082 - Malicious Domain DNS Match

Domain	Threat Intelligence & IOC
ATT&CK	T1071.004 DNS
Severity	High
Window	5m
Telemetry	Threat intel, DNS
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-163
ATT&CK v19.2 Artifact	Contextual: IOC match is an intelligence artifact, not a one-to-one ATT&CK DET; correlate domain hits with DNS/C2 behavior analytics
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - match domain/subdomain queries to active threat-intelligence indicators with normalized FQDN handling - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Match domain/subdomain queries to active threat-intelligence indicators with normalized FQDN handling GROUP/RELATE BY source host and queried domain WITHIN 5m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Use confidence and expiry; maintain sinkhole/test-domain exclusions
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.

- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Match domain/subdomain queries to active threat-intelligence indicators with normalized FQDN handling
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Replay a .invalid IOC query in test DNS telemetry

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'Malicious Domain DNS Match'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-083 - Malicious File Hash Observed on Endpoint

Domain	Threat Intelligence & IOC
ATT&CK	T1105 Ingress Tool Transfer
Severity	Critical
Window	5m
Telemetry	Threat intel, EDR/file telemetry
Fields	timestamp, user, host, process_name, file_path, classification, bytes, destination, action, count
Source Library ID	DE-165
ATT&CK v19.2 Artifact	Contextual: File hash is an IOC; correlate with process/file execution and DET0060 or other technique-specific behavioral strategies
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - match SHA-256 preferably, with MD5/SHA1 as supplementary, against active malware indicators; enrich signer/path/process - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Match SHA-256 preferably, with MD5/SHA1 as supplementary, against active malware indicators; enrich signer/path/process GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Verify hash source/confidence and possible benign collisions for weak hashes; prefer SHA-256
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.

- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Match SHA-256 preferably, with MD5/SHA1 as supplementary, against active malware indicators; enrich signer/path/process
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Use an EICAR-like harmless custom test hash or synthetic file event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'Malicious File Hash Observed on Endpoint'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-084 - Same IOC Observed Across Multiple Hosts

Domain	Threat Intelligence & IOC
ATT&CK	T1071 Application Layer Protocol
Severity	Critical
Window	30m
Telemetry	Threat intel, SIEM correlation across endpoint/network/DNS
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-169
ATT&CK v19.2 Artifact	Contextual: Cross-host IOC clustering is a SOC correlation artifact; map follow-on behavior to technique-specific DETs
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate the same active IOC appearing on multiple internal hosts/users within a short window to identify broader compromise - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate the same active IOC appearing on multiple internal hosts/users within a short window to identify broader compromise GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Deduplicate infrastructure-wide proxy/DNS artifacts; group by actual endpoints
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate the same active IOC appearing on multiple internal hosts/users within a short window to identify broader compromise
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Replay synthetic IOC hits from three lab hosts and verify one incident case

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'Same IOC Observed Across Multiple Hosts'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-085 - IOC Hit Followed by Suspicious Behaviour

Domain	Threat Intelligence & IOC
ATT&CK	T1071; T1059; T1105
Severity	Critical
Window	30m
Telemetry	Threat intel plus EDR/identity/network
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-170
ATT&CK v19.2 Artifact	Composite: IOC signal plus behavioral DETs; common combinations include DET0060 (Ingress Tool Transfer), DET0516 (Command/Scripting), and DET0444 (Application-Layer C2)
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate an IOC match with execution, credential access, privilege change, or lateral movement on same entity within a defined interval - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate an IOC match with execution, credential access, privilege change, or lateral movement on same entity within a defined interval GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Keep IOC as context; require behavioral confirmation for highest severity
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate an IOC match with execution, credential access, privilege change, or lateral movement on same entity within a defined interval
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Block or sinkhole confirmed malicious destinations at the appropriate control when safe and scoped.
- Identify every internal system that communicated with the indicator/destination and investigate them as a cluster.
- Preserve relevant DNS, proxy, firewall, and endpoint network evidence.

SAFE VALIDATION

Replay IOC hit followed by synthetic suspicious process and login events for one lab host

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 11:02 - Host initiates the first relevant network/DNS event.
- 11:05 - Pattern matches 'IOC Hit Followed by Suspicious Behaviour'.
- 11:06 - Destination reputation, process, asset criticality, and peer activity are attached to the case.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

18. Vulnerability & Exposure

Connect external exposure and vulnerability state to active exploitation signals so defenders can prioritize attacks against genuinely vulnerable assets.

ID	Rule	Severity
DE-086	Exploit Attempt Against KEV-Listed Critical Asset	Critical
DE-087	Reconnaissance Followed by Exploit Attempt	High
DE-088	New Internet-Facing Service Detected	High
DE-089	Exploit Payload Followed by Shell Spawn	Critical
DE-090	Critical Vulnerability Asset Contacts Rare External Destination	Critical

DE-086 - Exploit Attempt Against KEV-Listed Critical Asset

Domain	Vulnerability & Exposure
ATT&CK	T1190 Exploit Public-Facing Application
Severity	Critical
Window	5m
Telemetry	Vulnerability inventory, CISA KEV feed, WAF/IDS, asset inventory
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-171
ATT&CK v19.2 Artifact	Direct/Contextual: DET0080 - Exploit Public-Facing Application - multi-signal correlation; KEV status is risk enrichment, not an ATT&CK object
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate exploit signature or suspicious request with a currently vulnerable asset whose CVE is in KEV or otherwise high exploitation priority - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate exploit signature or suspicious request with a currently vulnerable asset whose CVE is in KEV or otherwise high exploitation priority GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Keep asset-vulnerability state current; suppress only after verified remediation/mitigation
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate exploit signature or suspicious request with a currently vulnerable asset whose CVE is in KEV or otherwise high exploitation priority
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.

- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Replay a harmless exploit-signature test against a lab asset tagged with a dummy critical exposure

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Exploit Attempt Against KEV-Listed Critical Asset' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-087 - Reconnaissance Followed by Exploit Attempt

Domain	Vulnerability & Exposure
ATT&CK	T1595 Active Scanning; T1190 Exploit Public-Facing Application
Severity	High
Window	30m
Telemetry	WAF, firewall, IDS, exposure inventory
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-173
ATT&CK v19.2 Artifact	Composite: DET0830 - Detection of Active Scanning; DET0080 - Exploit Public-Facing Application multi-signal correlation
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate scanning/probing of an exposed service with a subsequent exploit pattern from same or related source infrastructure - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate scanning/probing of an exposed service with a subsequent exploit pattern from same or related source infrastructure GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved penetration tests and external scanners; consider distributed scanners
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate scanning/probing of an exposed service with a subsequent exploit pattern from same or related source infrastructure
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.

- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.
- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Replay synthetic scan records followed by harmless exploit-signature event in lab

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Reconnaissance Followed by Exploit Attempt' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-088 - New Internet-Facing Service Detected

Domain	Vulnerability & Exposure
ATT&CK	Exposure-management control; ATT&CK contextual mapping to T1190 risk
Severity	High
Window	1h
Telemetry	EASM, firewall NAT, cloud inventory, CMDB
Fields	timestamp, principal, source_ip, session_id, action, resource, region, result, user_agent, device_id
Source Library ID	DE-175
ATT&CK v19.2 Artifact	Contextual: Exposure-management control; use current T1190/DET0080 coverage once attack activity reaches the newly exposed service
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - alert when a new public IP, hostname, port, service, or cloud endpoint appears without known asset owner or approved change - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Alert when a new public IP, hostname, port, service, or cloud endpoint appears without known asset owner or approved change
GROUP/RELATE BY user/host/source entity WITHIN 1h THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Integrate deployment pipeline and change system; confirm exposure before paging SOC
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Alert when a new public IP, hostname, port, service, or cloud endpoint appears without known asset owner or approved change
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.
- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Create a temporary approved lab listener/public endpoint and confirm EASM/CMDB correlation

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'New Internet-Facing Service Detected' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-089 - Exploit Payload Followed by Shell Spawn

Domain	Vulnerability & Exposure
ATT&CK	T1190 Exploit Public-Facing Application; T1059
Severity	Critical
Window	5m
Telemetry	WAF/IDS, EDR process
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-177
ATT&CK v19.2 Artifact	Composite: DET0080 - Exploit Public-Facing Application multi-signal correlation; DET0394 - Web Shell Detection where applicable
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate exploit alert targeting server with web/app process spawning shell/interpreter soon afterward - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate exploit alert targeting server with web/app process spawning shell/interpreter soon afterward GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved maintenance hooks only if exact process tree is known
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.

- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate exploit alert targeting server with web/app process spawning shell/interpreter soon afterward
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.
- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Replay synthetic exploit alert plus benign web-server-to-shell process event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Exploit Payload Followed by Shell Spawn' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-090 - Critical Vulnerability Asset Contacts Rare External Destination

Domain	Vulnerability & Exposure
ATT&CK	T1190 Exploit Public-Facing Application; T1071
Severity	Critical
Window	15m
Telemetry	Vulnerability inventory, EDR/network, domain prevalence
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-179
ATT&CK v19.2 Artifact	Composite: DET0080 - Exploit Public-Facing Application; DET0444 - Detection of Command and Control Over Application Layer Protocols
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect a high-risk unpatched asset initiating a new external connection, especially shortly after exploit scanning - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect a high-risk unpatched asset initiating a new external connection, especially shortly after exploit scanning GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline vendor update destinations and monitoring; include process identity
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.

- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect a high-risk unpatched asset initiating a new external connection, especially shortly after exploit scanning
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Apply WAF/IPS or network containment for confirmed exploit traffic while preserving availability.
- Isolate or restrict the affected service if exploitation is confirmed; capture server/process evidence.
- Coordinate emergency remediation/patching or compensating controls with the service owner.

SAFE VALIDATION

Replay synthetic rare-destination connection from a lab asset tagged critical-vulnerable

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Critical Vulnerability Asset Contacts Rare External Destination' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

19. Detection Health & Telemetry

Monitor the monitoring system itself: sensor availability, log volume, parsing quality, timestamps, rule state, and validation freshness.

ID	Rule	Severity
DE-091	Critical Log Source Stops Sending	Critical
DE-092	EDR Heartbeat Gap	High
DE-093	Parser or Normalization Field NULL Spike	High
DE-094	SIEM EPS or Ingestion Drops Below Baseline	High
DE-095	Detection Rule Disabled or Modified in Production	Critical

DE-091 - Critical Log Source Stops Sending

Domain	Detection Health & Telemetry
ATT&CK	T1562.001 Impair Defenses - contextual
Severity	Critical
Window	10m
Telemetry	SIEM ingestion metrics, log source inventory

Fields	timestamp, source, source_type, event_rate, last_seen, expected_rate, null_ratio, rule_id, change_actor, status
Source Library ID	DE-181
ATT&CK v19.2 Artifact	Contextual: DET0900 - Detection of Defense Impairment when telemetry loss follows suspicious activity; otherwise treat as detection-health engineering control
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - alert when a critical source sends zero events beyond its normal tolerance while host/service is otherwise reachable - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Alert when a critical source sends zero events beyond its normal tolerance while host/service is otherwise reachable GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Use source-specific heartbeat expectations and maintenance windows; distinguish low-volume sources
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Alert when a critical source sends zero events beyond its normal tolerance while host/service is otherwise reachable
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Restore telemetry or rule operation through the responsible platform team and document the blind interval.
- Determine whether the outage was operational, configuration-related, or malicious.
- Run retrospective hunts covering the blind interval once telemetry is restored.

SAFE VALIDATION

Pause only a lab/test forwarder or replay zero-volume metrics to verify health alert

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Critical Log Source Stops Sending' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-092 - EDR Heartbeat Gap

Domain	Detection Health & Telemetry
ATT&CK	T1562.001 Impair Defenses - contextual

Severity	High
Window	10m
Telemetry	EDR console/API, asset inventory
Fields	timestamp, host, user, process_name, process_path, parent_process, command_line, hash_sha256, signer, destination
Source Library ID	DE-182
ATT&CK v19.2 Artifact	Contextual: DET0900 - Detection of Defense Impairment when heartbeat loss is associated with adversary activity
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect endpoint sensor heartbeat older than threshold, especially for critical server or immediately after suspicious activity - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect endpoint sensor heartbeat older than threshold, especially for critical server or immediately after suspicious activity GROUP/RELATE BY user/host/source entity WITHIN 10m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Account for powered-off laptops, maintenance, and network isolation; use asset class
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect endpoint sensor heartbeat older than threshold, especially for critical server or immediately after suspicious activity
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Restore telemetry or rule operation through the responsible platform team and document the blind interval.
- Determine whether the outage was operational, configuration-related, or malicious.
- Run retrospective hunts covering the blind interval once telemetry is restored.

SAFE VALIDATION

Replay synthetic heartbeat timestamps for a lab host beyond threshold

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'EDR Heartbeat Gap' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-093 - Parser or Normalization Field NULL Spike

Domain	Detection Health & Telemetry
ATT&CK	Detection engineering control
Severity	High
Window	30m
Telemetry	SIEM parser metrics, schema validation
Fields	timestamp, source, source_type, event_rate, last_seen, expected_rate, null_ratio, rule_id, change_actor, status
Source Library ID	DE-185
ATT&CK v19.2 Artifact	Engineering: No direct ATT&CK technique required - parser/normalization health is a Detection Engineering assurance control
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect sudden increase in NULL/unknown values for fields required by detections such as user, host, process, action, src/dst IP - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect sudden increase in NULL/unknown values for fields required by detections such as user, host, process, action, src/dst IP GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Track expected optional fields separately; compare against deployment/schema changes
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect sudden increase in NULL/unknown values for fields required by detections such as user, host, process, action, src/dst IP
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Restore telemetry or rule operation through the responsible platform team and document the blind interval.
- Determine whether the outage was operational, configuration-related, or malicious.
- Run retrospective hunts covering the blind interval once telemetry is restored.

SAFE VALIDATION

Replay test events missing required normalized fields and verify data-quality alert

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Parser or Normalization Field NULL Spike' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.

- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-094 - SIEM EPS or Ingestion Drops Below Baseline

Domain	Detection Health & Telemetry
ATT&CK	Defense monitoring control
Severity	High
Window	15m
Telemetry	SIEM platform metrics
Fields	timestamp, source, source_type, event_rate, last_seen, expected_rate, null_ratio, rule_id, change_actor, status
Source Library ID	DE-187
ATT&CK v19.2 Artifact	Engineering: No direct ATT&CK technique required - SIEM ingestion health is a Detection Engineering assurance control
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect sustained EPS decrease beyond expected band for environment or critical domain, especially without traffic/service outage - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect sustained EPS decrease beyond expected band for environment or critical domain, especially without traffic/service outage GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a HIGH detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Model day-of-week and maintenance; monitor source counts as well as total EPS
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect sustained EPS decrease beyond expected band for environment or critical domain, especially without traffic/service outage
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- Contain only after validation or when the risk context justifies precautionary action; avoid disrupting legitimate business activity unnecessarily.
- Restore telemetry or rule operation through the responsible platform team and document the blind interval.
- Determine whether the outage was operational, configuration-related, or malicious.
- Run retrospective hunts covering the blind interval once telemetry is restored.

SAFE VALIDATION

Replay synthetic EPS metric below threshold for a lab tenant/index

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.

- 10:24 - The pattern for 'SIEM EPS or Ingestion Drops Below Baseline' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-095 - Detection Rule Disabled or Modified in Production

Domain	Detection Health & Telemetry
ATT&CK	T1562.001 Impair Defenses - contextual
Severity	Critical
Window	5m
Telemetry	SIEM audit, Git/change control
Fields	timestamp, user, repo, action, branch, runner, workflow, artifact, source_ip, result
Source Library ID	DE-190
ATT&CK v19.2 Artifact	Direct/Contextual: DET0900 - Detection of Defense Impairment; correlate production-rule disablement with actor/change context
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - detect disabling, deletion, severity reduction, query change, or exception change to critical rules outside approved deployment workflow - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Detect disabling, deletion, severity reduction, query change, or exception change to critical rules outside approved deployment workflow GROUP/RELATE BY user/host/source entity WITHIN 5m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Allow CI/CD service identity and approved emergency change with audit trail
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Detect disabling, deletion, severity reduction, query change, or exception change to critical rules outside approved deployment workflow
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Restore telemetry or rule operation through the responsible platform team and document the blind interval.
- Determine whether the outage was operational, configuration-related, or malicious.
- Run retrospective hunts covering the blind interval once telemetry is restored.

SAFE VALIDATION

Replay synthetic SIEM rule-disable audit event by an unauthorized lab actor

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:21 - Initial telemetry for the test host/process appears.
- 10:24 - The pattern for 'Detection Rule Disabled or Modified in Production' is satisfied.
- 10:26 - Analyst pivots to parent/child activity, user/session context, and subsequent network or identity behavior.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-

20. Cross-Source Correlation & Attack Chains

Promote related low-level signals into high-confidence attack stories that reflect progression across multiple ATT&CK stages.

ID	Rule	Severity
DE-096	Phishing Delivery -> Click -> New Sign-in	Critical
DE-097	Credential Access -> Privileged Login	Critical
DE-098	EDR Impairment -> Remote Movement	Critical
DE-099	Archive Creation -> Large External Upload	Critical
DE-100	Ransomware Pre-Impact Chain	Critical

DE-096 - Phishing Delivery -> Click -> New Sign-in

Domain	Cross-Source Correlation & Attack Chains
ATT&CK	T1566 Phishing; T1078 Valid Accounts
Severity	Critical
Window	1h
Telemetry	Email, click telemetry, proxy/DNS, IdP
Fields	timestamp, sender, recipient, subject, message_id, sender_ip, url, attachment_name, authentication_result, action
Source Library ID	DE-191
ATT&CK v19.2 Artifact	Composite: DET0878 - Detection of Spearphishing Link; DET0560 - Detection of Valid Account Abuse Across Platforms
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate user receiving suspicious email, clicking its URL, then authenticating from a new device/source within one hour - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate user receiving suspicious email, clicking its URL, then authenticating from a new device/source within one hour GROUP/RELATE BY user account and source/device WITHIN 1h THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Require same user/recipient identity and URL/domain lineage; exclude security-awareness simulations by campaign tag
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate user receiving suspicious email, clicking its URL, then authenticating from a new device/source within one hour
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.

- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Run an approved phishing simulation using internal training URL and synthetic new-sign-in event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:00 - First stage signal appears.
- 10:07 - Related signal matches: Phishing Delivery -> Click -> New Sign-in.
- 10:12 - Correlation threshold is met; one high-confidence case is created with linked events.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-097 - Credential Access -> Privileged Login

Domain	Cross-Source Correlation & Attack Chains
ATT&CK	T1003 OS Credential Dumping; T1078 Valid Accounts
Severity	Critical
Window	20m
Telemetry	EDR credential-access, authentication, PAM
Fields	timestamp, user, source_ip, device_id, result, auth_method, risk_level, app, location, session_id
Source Library ID	DE-193
ATT&CK v19.2 Artifact	Composite: DET0234 - Credential Dumping via Sensitive Memory and Registry Access Correlation; DET0560 - Valid Account Abuse
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate credential-access signal on host with subsequent privileged authentication by same user or from same source host - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate credential-access signal on host with subsequent privileged authentication by same user or from same source host
GROUP/RELATE BY user account and source/device WITHIN 20m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude approved security testing and credential rotation; require temporal/entity linkage
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate credential-access signal on host with subsequent privileged authentication by same user or from same source host
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Replay synthetic credential-access alert followed by lab privileged-logon event

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:00 - First stage signal appears.
- 10:07 - Related signal matches: Credential Access -> Privileged Login.
- 10:12 - Correlation threshold is met; one high-confidence case is created with linked events.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-098 - EDR Impairment -> Remote Movement

Domain	Cross-Source Correlation & Attack Chains
ATT&CK	T1562.001 Impair Defenses; T1021 Remote Services
Severity	Critical
Window	15m
Telemetry	EDR health, Windows/Linux auth, network
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-195
ATT&CK v19.2 Artifact	Composite: DET0900 - Detection of Defense Impairment; DET0269/DET0327/DET0530/DET0477 according to remote-movement method
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate security-agent stop/heartbeat loss with outbound remote-service authentication from the affected host soon afterward - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate security-agent stop/heartbeat loss with outbound remote-service authentication from the affected host soon afterward GROUP/RELATE BY user/host/source entity WITHIN 15m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Exclude planned agent upgrades/reboots using maintenance data
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate security-agent stop/heartbeat loss with outbound remote-service authentication from the affected host soon afterward
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.

- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Replay synthetic agent-stop and heartbeat-gap events followed by lab SMB/RDP authentication

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:00 - First stage signal appears.
- 10:07 - Related signal matches: EDR Impairment -> Remote Movement.
- 10:12 - Correlation threshold is met; one high-confidence case is created with linked events.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-099 - Archive Creation -> Large External Upload

Domain	Cross-Source Correlation & Attack Chains
ATT&CK	T1560 Archive Collected Data; T1041 Exfiltration Over C2 Channel
Severity	Critical
Window	30m
Telemetry	EDR file/process, proxy/firewall, DLP
Fields	timestamp, source_ip, source_host, destination_ip, destination_port, protocol, action, bytes_out, domain, process_name
Source Library ID	DE-196
ATT&CK v19.2 Artifact	Composite: DET0298 - Detect Archiving via Utility; DET0348 - Detection Strategy for Exfiltration Over C2 Channel
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate newly created archive containing many files with large upload by same user/host to rare or unsanctioned destination - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate newly created archive containing many files with large upload by same user/host to rare or unsanctioned destination GROUP/RELATE BY user/host/source entity WITHIN 30m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Baseline backup/sync/package workflows; require external destination or sensitive data context
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.
- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.

- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate newly created archive containing many files with large upload by same user/host to rare or unsanctioned destination
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Create a small dummy archive and replay synthetic high-byte upload to reserved test domain

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:00 - First stage signal appears.
- 10:07 - Related signal matches: Archive Creation -> Large External Upload.
- 10:12 - Correlation threshold is met; one high-confidence case is created with linked events.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
- Positive and negative test cases passed.
- Expected benign activity documented; exclusions are narrow and expiry-controlled.
- Alert contains investigation pivots and owner/runbook information.
- Response action and escalation path are documented.
- Rule has an owner, review date, version, and last-validation timestamp.

DE-100 - Ransomware Pre-Impact Chain

Domain	Cross-Source Correlation & Attack Chains
ATT&CK	T1003 Credential Dumping; T1018 Discovery; T1562.001 Impair Defenses; T1490 Inhibit System Recovery
Severity	Critical
Window	60m
Telemetry	EDR, identity, network, backup, SIEM health
Fields	timestamp, source, source_type, event_rate, last_seen, expected_rate, null_ratio, rule_id, change_actor, status
Source Library ID	DE-200
ATT&CK v19.2 Artifact	Composite: DET0234 - Credential Dumping; DET0376 - Network Service Discovery; DET0900 - Defense Impairment; DET0329 - Inhibit System Recovery; DET0215 - File Encryption for Impact
Artifact Trace	Technique -> Detection Strategy (DET) -> platform Analytic (AN) -> Data Component (DC) -> enterprise log source. Validate against the live ATT&CK v19.2 record before production deployment.

THREAT HYPOTHESIS

If the organization observes the described pattern - correlate credential-access signal, internal discovery/lateral movement, defense impairment, and backup/recovery tampering before encryption occurs - the activity may represent the mapped attacker behavior or an important precursor that warrants investigation.

VENDOR-NEUTRAL DETECTION LOGIC

WHEN Correlate credential-access signal, internal discovery/lateral movement, defense impairment, and backup/recovery tampering before encryption occurs GROUP/RELATE BY user/host/source entity WITHIN 60m THEN create or raise a CRITICAL detection, enrich with asset/identity/threat context, and suppress only documented approved activity.

TUNING / FALSE-POSITIVE CONTROL

- Use risk scoring and allow partial chain matches; exclude controlled purple-team exercises by campaign tag
- Start with the documented threshold as a baseline, then measure normal volume for at least one representative business cycle before aggressive suppression.

- Prefer narrow, explainable exceptions using identity role, signer/hash, managed host group, approved destination, ticket/change ID, or fixed process lineage. Avoid blanket user/host exclusions.
- Review exceptions with an expiry date. Re-test the rule after parser, schema, EDR, SIEM, IdP, cloud, or application logging changes.

ANALYST INVESTIGATION

- Validate that the telemetry is complete, correctly parsed, and time-synchronised; confirm the event is not a duplicate or collector artifact.
- Identify the primary entity (user, host, process, application, token, source IP, or workload) and determine its business criticality and privilege level.
- Confirm the exact condition that matched: Correlate credential-access signal, internal discovery/lateral movement, defense impairment, and backup/recovery tampering before encryption occurs
- Build a timeline from at least 30 minutes before to 30 minutes after the trigger; expand the window when the technique is slow-moving.
- Pivot to related entities: other hosts used by the account, other accounts on the host, related destination domains/IPs, parent/child processes, and recent configuration changes.
- Check for preceding initial-access/execution signals and follow-on credential access, privilege escalation, lateral movement, collection, exfiltration, defense impairment, or impact.
- Record evidence and classify as true positive, benign true positive, false positive, test/simulation, or unresolved.

RESPONSE AFTER CONFIRMATION

- If malicious activity is confirmed or confidence is high enough under the incident policy, prioritize rapid containment while preserving evidence.
- Contain the affected entities based on the strongest confirmed stage of the attack chain.
- Preserve cross-source evidence and open/merge into a single incident case.
- Run retrospective searches for the same chain across the environment.

SAFE VALIDATION

Replay a full safe synthetic timeline across lab sources and confirm one ransomware-pre-impact case is created

Expected result: the required telemetry is ingested, the detection matches once, enrichment fields are present, the analyst can build the timeline, and the test is tagged so it cannot be mistaken for a real incident.

MINI SIMULATION TIMELINE

- 10:00 - First stage signal appears.
- 10:07 - Related signal matches: Ransomware Pre-Impact Chain.
- 10:12 - Correlation threshold is met; one high-confidence case is created with linked events.

PRODUCTION READINESS GATE

- Telemetry coverage verified for the intended asset/user scope.
 - Positive and negative test cases passed.
 - Expected benign activity documented; exclusions are narrow and expiry-controlled.
 - Alert contains investigation pivots and owner/runbook information.
 - Response action and escalation path are documented.
 - Rule has an owner, review date, version, and last-validation timestamp.
-